DOCUMENTACIÓN CONSOLIDADA

Sistema De Todito Reyes

Gestión de inventario, clientes y facturación en bolívares con tasa BCV, IVA e IGTF.

ADMIN · control total **CAJERO · punto de venta**

Manual de usuario
Operación diaria del sistema para ADMIN y CAJERO.

Manual de instalación
Requisitos, despliegue, respaldo y endurecimiento.

Revisión técnica
Hallazgos, riesgos y plan de acción recomendado.

Diagramas de casos de uso
Vista general y por rol, con include y extend.

Documento generado el 06/11/2026 · Versión 1.0

DOCUMENTO 1 DE 3 · USO

Manual de usuario — Sistema De Todito Reyes

Versión del documento: 1.0
Sistema: De Todito Reyes — Gestión y facturación
Roles: ADMIN (administrador) y CAJERO
Fecha: 6 de noviembre de 2026
Documentos relacionados: Manual de instalación · Revisión técnica · Diagramas de casos de uso

---

1. Introducción

De Todito Reyes es un sistema para administrar clientes, productos, inventario, mermas, tasas de cambio del BCV y facturación en bolívares con IVA e IGTF. Está pensado para un negocio pequeño con dos perfiles:

- **ADMIN:** control total del negocio, inventario, precios, usuarios, tasas y facturas.
- **CAJERO:** opera el punto de venta, registra clientes y consulta la información necesaria para vender.

El sistema funciona en un navegador web. No requiere instalar programas en la computadora del cajero; solo necesita la dirección del servidor y un usuario activo.

> **Importante:** el sistema no envía correos ni mensajes automáticos. La tasa BCV se registra manualmente y las contraseñas se cambian desde el módulo **Usuarios** o, si nadie puede entrar, con el script de consola descrito en el manual de instalación.

---

2. Requisitos para usar el sistema

- Un navegador actualizado: Chrome, Edge, Firefox o Safari.
- Conexión a la red donde está instalado el servidor.
- Usuario y contraseña activos.
- Resolución mínima recomendada: 1366 × 768. En pantallas pequeñas el menú lateral se puede abrir con el botón ☰.

No se necesita conexión a internet para operar, salvo que se quiera consultar el valor oficial en `bcv.org.ve` desde el enlace del módulo **Tasas**.

---

3. Acceso al sistema

3.1 Dirección

La dirección depende de cómo se instaló:

INSTALACIÓN	DIRECCIÓN TÍPICA
Apache con el proyecto en `htdocs`	`http://localhost/revisionSistema/public/`
Apache con `DocumentRoot` en `public/`	`http://localhost/`
Servidor embebido de PHP	`http://127.0.0.1:8000/`

La raíz `/` siempre muestra el inicio de sesión. El panel está en `/panel` y no se puede abrir sin sesión activa.

3.2 Iniciar sesión

1. Abre la dirección del sistema.
2. Escribe tu **Usuario**.
3. Escribe tu **Contraseña**.
4. Pulsa **Entrar**.

Si los datos son correctos, el sistema te lleva al panel que corresponde a tu rol.

3.3 Credenciales de demostración

USUARIO	CONTRASEÑA	ROL
`admin`	`admin123`	ADMIN
`mcajera`	`cajera123`	CAJERO

> **Cambia estas contraseñas antes de usar el sistema en producción.** Si las cuentas demo no se van a usar, desactívalas desde **Usuarios**.

3.4 Si olvidaste la contraseña

- Si eres **CAJERO**, pide al ADMIN que restablezca tu contraseña desde **Usuarios**.
- Si eres **ADMIN** y no puedes entrar, usa el script de consola `tools/crear_admin.php` (ver manual de instalación). Ese script no funciona desde el navegador.

3.5 Cerrar sesión

Pulsa **Cerrar sesión** al final del menú lateral. El cierre se hace por `POST` con protección CSRF; no existe un enlace `GET /logout` que cierre la sesión.

La sesión se cierra automáticamente después de **30 minutos de inactividad**. Si tu cuenta es desactivada o eliminada mientras estás conectado, la siguiente petición te llevará al login con un aviso.

3.6 Comportamiento del navegador

- Las páginas autenticadas no se guardan en caché. El botón **Atrás** no debe mostrar el panel después de cerrar sesión.
- Si abres `/` con una sesión abierta, el sistema cierra esa sesión y te pide la contraseña de nuevo. Es intencional.
- Si ves un error **419**, la sesión expiró o el formulario perdió el token de seguridad. Recarga la página e inténtalo de nuevo.

---

4. Roles y permisos

4.1 Tabla de permisos

ACCIÓN	ADMIN	CAJERO
Iniciar y cerrar sesión	✓	✓
Ver el panel administrativo	✓	✗
Ver el panel personal de ventas	✓	✓
Consultar clientes	✓	✓
Registrar clientes nuevos	✓	✓
Editar o eliminar clientes	✓	✗
Consultar productos e inventario	✓	✗
Crear, editar, activar/desactivar o eliminar productos	✓	✗
Emitir facturas en el POS	✓	✓
Consultar historial de ventas y comprobantes	✓	✓
Descargar PDF, PNG o imprimir	✓	✓
Exportar resumen o detalle CSV	✓	✓
Consultar la tasa BCV y su historial	✓	✓
Registrar o corregir la tasa BCV	✓	✗
Anular facturas	✓	✗
Eliminar facturas anuladas	✓	✗
Registrar mermas	✓	✓
Consultar mermas	✓	✓
Ver costos y pérdidas por merma	✓	✗
Gestionar usuarios	✓	✗

4.2 Menú según el rol

ADMIN:

- Panel
- Productos
- Clientes
- Facturación
- Merma
- Tasas
- Usuarios
- Nueva venta

CAJERO:

- Mi panel
- Clientes
- Facturación
- Merma
- Nueva venta

El CAJERO no ve **Productos**, **Tasas** ni **Usuarios**. Si intenta abrir `/productos` o `/usuarios` escribiendo la dirección, el servidor lo redirige a su panel con un aviso. Las restricciones no dependen de ocultar botones: se validan en el servidor.

---

5. Panel principal

5.1 Panel del ADMIN

Al entrar como ADMIN, el panel muestra:

TARJETA O SECCIÓN	QUÉ SIGNIFICA
Productos activos	Cantidad de productos con `activo = 1` y número de categorías.
Clientes	Total de clientes registrados.
Facturas emitidas	Total de facturas en estado `EMITIDA` y cantidad de mermas.
Tasa BCV vigente	Valor del dólar y fecha de vigencia. Si está desactualizada, aparece un enlace a **Tasas**.
Inventario a costo	Valor del stock actual multiplicado por el costo en USD.
Inventario a precio de venta	Valor del stock actual multiplicado por el precio de venta en USD.
Total vendido	Suma de facturas emitidas en USD y Bs.
Stock bajo	Productos en o por debajo del stock mínimo, con el faltante.
Más vendidos	Top 5 de productos por cantidad vendida.
Últimas facturas	Movimientos recientes con enlace al comprobante.
Pérdidas por merma	Aparece si hay pérdidas acumuladas.

5.2 Panel del CAJERO (“Mi panel”)

El CAJERO ve solo su actividad:

- **Tus facturas de hoy:** cantidad de facturas emitidas hoy por su usuario.
- **Vendido hoy:** total en Bs y USD de sus ventas de hoy.
- **Facturas del mes:** cantidad y total vendido en el mes.
- **Tasa BCV vigente:** valor y fecha; si está desactualizada, aviso para pedir al ADMIN.
- **Accesos rápidos:** botones **Nueva venta** e **Historial de ventas**.

- **Tu actividad:** facturas emitidas, total vendido y última venta.
- **Tus últimas facturas:** movimientos recientes emitidos por su usuario.

El panel del CAJERO **no** muestra inventario, costos, pérdidas, productos ni datos de otros usuarios.

---

6. Clientes

Ruta: **Clientes** (`/clientes`).

6.1 Consultar

1. Entra a **Clientes**.
2. Usa el campo **Buscar** por nombre, cédula o RIF.
3. Pulsa **Filtrar**.
4. Pulsa **Limpiar** para ver todos.

La tabla muestra cliente, RIF/cédula, teléfono, dirección y cantidad de facturas.

6.2 Registrar un cliente

Pueden hacerlo ADMIN y CAJERO.

1. En **Nuevo cliente**, completa:
   - **Cédula o RIF:** obligatorio. Formato `V-12345678` o `J-12345678-9`. Letras permitidas: `V` , `E` , `J` , `G` , `P` ; guion; entre 6 y 9 dígitos; opcional un dígito final.
   - **Nombre o razón social:** obligatorio, máximo 120 caracteres.
   - **Dirección fiscal:** opcional, máximo 180 caracteres.
   - **Teléfono:** opcional, máximo 25 caracteres.
2. Pulsa **Registrar cliente**.
3. Si el RIF/cédula ya existe, el sistema muestra “Ya existe otro cliente con esa cédula o RIF.”

6.3 Editar o eliminar

Solo el ADMIN ve los botones **Editar** y **Eliminar**.

- **Editar:** abre el formulario con los datos actuales; pulsa **Guardar cambios**.
- **Eliminar:** solo se permite si el cliente **no tiene facturas**. Si tiene, el botón aparece deshabilitado y el servidor también rechaza el borrado. En ese caso, edita los datos en lugar de borrar.

El CAJERO puede consultar y crear clientes, pero no editar ni eliminar. Si lo intenta por URL o por un POST manipulado, el servidor responde con “Solo un administrador puede editar o eliminar clientes.”

---

7. Productos e inventario (solo ADMIN)

Ruta: **Productos** (`/productos`).

7.1 Conceptos importantes

- **Costo en USD:** lo que cuesta adquirir el producto.
- **Precio de venta en USD:** lo que se cobra al cliente.
- **Costo/Precio en Bs (BCV):** campo de referencia calculado con la tasa vigente. No se guarda en la base; el POS aplica la tasa del momento de la venta.
- **Alícuota IVA:** porcentaje de IVA del producto. Valores habituales: `0` (exento), `8` (reducida) y `16` (general). Se permiten valores entre 0 y 100.
- **Stock actual / mínimo / máximo:** cantidades en la unidad de medida. El stock máximo es opcional.

7.2 Crear un producto

1. Entra a **Productos**.
2. En **Nuevo producto**, completa:
   - **Nombre del producto:** obligatorio, máximo 120 caracteres.
   - **Código de barras / QR:** obligatorio, máximo 64 caracteres y único.
   - **Categoría:** obligatoria.
   - **Unidad de medida:** Unidad (`UND`), Kilogramo (`KG`), Litro (`LT`), Gramo (`GR`) o Paquete (`PAQ`).
   - **Alícuota IVA (%):** 0, 8 o 16, o el valor que corresponda.
   - **Costo en USD:** mayor o igual a 0.
   - **Precio de venta en USD:** mayor o igual a 0.
   - **Stock actual**, **Stock mínimo** y, si aplica, **Stock máximo:** mayores o iguales a 0.
3. Pulsa **Crear producto**.

Si no hay tasa BCV registrada, el sistema avisa que no puede calcular los equivalentes en Bs. Puedes guardar el producto igualmente; el cálculo en Bs se actualizará cuando exista una tasa.

7.3 Editar, activar y desactivar

- **Editar:** abre el formulario con los datos actuales. Pulsa **Guardar cambios**.
- **Desactivar:** el producto deja de aparecer en el POS y en los listados por defecto, pero conserva su historial. Pulsa **Reactivar** para volver a usarlo.
- **Eliminar:** solo se permite si el producto **no tiene ventas, compras ni mermas**. Si tiene historial, el sistema lo rechaza y sugiere desactivarlo.

7.4 Buscar y filtrar

- **Buscar:** por nombre o código.
- **Categoría:** filtra por categoría.
- **Solo stock bajo:** muestra productos con `stock_actual <= stock_minimo` .

- **Incluir inactivos:** muestra también los desactivados.
- **Limpiar:** quita todos los filtros.

La tabla muestra costo y precio en USD con su equivalente en Bs, IVA, stock con color (verde/amarillo/rojo) y estado.

7.5 Buenas prácticas de inventario

- Usa códigos únicos y legibles.
- Revisa el **Stock bajo** del panel antes de abrir caja.
- No cambies el stock actual para "cuadrar" ventas: usa **Merma** para bajas justificadas.
- Desactiva en lugar de eliminar cuando el producto ya tenga historial.

---

8. Punto de venta (POS)

Ruta: **Nueva venta** (`/facturacion/nueva`). Disponible para ADMIN y CAJERO.

8.1 Antes de vender

Verifica:

1. Que exista una **tasa BCV** registrada. Sin tasa, el servidor no permite emitir.
2. Que la tasa sea del día. Si está desactualizada, el sistema muestra un aviso; puedes vender, pero los totales usarán esa tasa.
3. Que haya **clientes** registrados. Si no hay, el POS muestra un enlace para crear uno.
4. Que haya **productos activos** con stock. Si no hay, muestra un enlace a Productos (solo ADMIN) o pide al ADMIN.

8.2 Pasos para emitir una factura

1. Entra a **Nueva venta**.
2. En el catálogo, busca el producto por nombre o código y pulsa **Agregar**.
    - También puedes usar el buscador del catálogo.
    - Los productos sin stock tienen el botón deshabilitado.
3. En el **Carrito**, ajusta la **Cantidad**.
    - No puede superar el stock disponible.
    - Se permiten hasta 3 decimales para productos por peso o volumen.
4. Selecciona el **Cliente**.
5. Selecciona el **Método de pago**: Efectivo, Pago móvil, Punto de venta, Transferencia, Zelle o Mixto.
6. Marca **Pago en divisa (IGTF 3%)** solo si la venta se paga en divisa. El IGTF se calcula sobre el subtotal más IVA.
7. Revisa el resumen:

- Tasa BCV
- Exento
- Base imponible
- IVA
- IGTF 3% (si aplica)
- Total en Bs
- Equivalente en USD

8. Pulsa **Emitir factura**.

El servidor vuelve a leer precios, IVA, stock y tasa desde la base. El navegador solo envía el ID del producto y la cantidad. Si algo cambió (precio, stock, tasa), el servidor recalcula y, si no puede, revierte toda la operación.

8.3 Qué ocurre al emitir

- Se genera un **número de factura consecutivo** de 6 dígitos (`000001`).
- Se genera un **número de control fiscal** (`00-000001`).
- Se genera un **código de verificación** aleatorio de 8 caracteres (por ejemplo `RJKRMJC2`).
- Se descuenta el stock en la misma transacción.
- Se guarda la tasa aplicada, el cliente, el cajero y el método de pago.
- Se muestra el comprobante con un aviso de éxito.

Si dos cajas emiten al mismo tiempo, el sistema usa un bloqueo y hasta 3 reintentos para que no se repita el consecutivo.

8.4 Errores frecuentes del POS

MENSAJE	CAUSA	SOLUCIÓN
“Agrega al menos un producto al carrito.”	Carrito vacío	Agrega un producto.
“Selecciona un cliente.”	No se eligió cliente	Selecciona uno.
“No hay una tasa BCV vigente…”	No hay tasa registrada	Un ADMIN debe registrar la tasa.
“Stock insuficiente de … Disponible: …”	La cantidad supera el stock	Ajusta la cantidad o repón inventario.
“Uno de los productos ya no está disponible.”	El producto fue desactivado o eliminado	Actualiza el catálogo.
“El sistema está ocupado generando otra factura…”	Otra caja tiene el bloqueo	Espera unos segundos y reintenta.
“No se pudo generar un número de factura único…”	Colisión persistente	Reintenta; si continúa, contacta al ADMIN.

---

9. Comprobante de factura

Ruta: `/facturacion/ver/ID` . Se llega desde el historial, el panel o el aviso de emisión.

9.1 Contenido

- Nombre, RIF, dirección y teléfono de la empresa (configurados en `config/empresa.php`).
- Tipo **FACTURA**, número, control fiscal, código de verificación y fecha.
- Estado: `EMITIDA` o `ANULADA`.
- Cliente, RIF/cédula, dirección fiscal, método de pago, tasa aplicada y cajero.
- Líneas: producto, código, cantidad, precio USD, precio Bs, IVA y subtotal Bs.
- Totales: subtotal exento, base imponible, IVA, IGTF (si aplica), total Bs y total USD.
- Pie: agradecimiento, tipo de emisión y login del cajero.

9.2 Acciones

BOTÓN	QUÉ HACE	QUIÉN LO VE
Descargar PDF	Descarga un PDF generado en el servidor (`/facturacion/pdf/ID`).	ADMIN y CAJERO
Descargar imagen	Descarga un PNG generado con GD (`/facturacion/imagen/ID`).	ADMIN y CAJERO
Imprimir	Abre el PDF en una pestaña nueva (`?ver=1`) para imprimir sin la URL ni la fecha que agrega Chrome.	ADMIN y CAJERO
Anular factura	Cambia el estado a `ANULADA` y devuelve el stock. Solo si está `EMITIDA`.	Solo ADMIN
Eliminar factura	Borra la factura y sus líneas. Solo si está `ANULADA`.	Solo ADMIN

9.3 Anular una factura

1. Abre el comprobante de una factura `EMITIDA`.
2. Pulsa **Anular factura**.
3. Confirma la acción.

La factura queda `ANULADA`, el stock vuelve al inventario y la bitácora registra al usuario que anuló. **No se puede revertir** la anulación.

9.4 Eliminar una factura anulada

1. Abre una factura `ANULADA`.
2. Pulsa **Eliminar factura**.
3. Confirma.

Se borran la factura y sus líneas. El número de consecutivo no se reutiliza porque el sistema conserva el registro de emisión en la bitácora. Aun así, esta acción es delicada desde el punto de vista fiscal: úsala solo cuando corresponda y con respaldo previo.

9.5 PDF, PNG e impresión

- **PDF:** se genera con `PdfFactura`, sin librerías externas. No incluye la URL del sistema.

- **PNG:** se genera con `ImagenFactura` y la extensión GD. Si GD no está habilitada, el botón muestra un error; el PDF sigue funcionando.
- **Imprimir:** abre el PDF en el navegador. Si el navegador muestra su propia barra de impresión, desactiva "Encabezados y pies" para un resultado más limpio.

---

10. Historial de ventas

Ruta: **Facturación** (`/facturacion`).

10.1 Tarjetas superiores

- **Facturas de hoy:** cantidad de facturas emitidas hoy (todas, no solo las tuyas).
- **Vendido hoy (Bs):** total en Bs y USD.
- **Tasa BCV:** valor y fecha.

10.2 Filtros

CAMPO	USO
Buscar	Número de factura, control fiscal, código de verificación, cliente o RIF/cédula.
Desde	Fecha inicial (`YYYY-MM-DD`).
Hasta	Fecha final.
Estado	Todos, Emitidas o Anuladas.
Filtrar	Aplica los filtros.
Limpiar	Quita los filtros.

El listado muestra hasta **100 facturas** (las más recientes). Las exportaciones CSV incluyen **todas** las que coincidan con los filtros, no solo las 100 visibles.

10.3 Exportar CSV

- **Resumen CSV:** una fila por factura. Incluye factura, control, fecha, cliente, RIF/cédula, cajero, método de pago, estado, subtotal exento, base imponible, IVA, IGTF, total Bs, total USD y tasa aplicada.
- **Detalle CSV:** una fila por producto vendido. Incluye factura, control, fecha, cliente, RIF/cédula, cajero, código, producto, unidad, cantidad/peso, precio USD, precio Bs, alícuota, IVA, subtotal y estado.

Los archivos usan UTF-8 con BOM, separador `;`, decimales con coma y punto de miles, para abrirse correctamente en Excel en español. El nombre incluye fecha y hora.

10.4 Abrir un comprobante

Pulsa el número de factura (`#000001`) o **Ver** para abrir el comprobante.

10.5 Eliminar desde el historial

El ADMIN ve el botón **Eliminar** solo en facturas `ANULADA`. Es equivalente a eliminarla desde el comprobante.

---

11. Tasas BCV

Ruta: **Tasas** (`/tasas`). Todos los usuarios autenticados pueden consultar; solo el ADMIN puede registrar o corregir.

11.1 Consultar

La pantalla muestra:

- **Tasa BCV vigente:** Bs por 1 USD.
- **Última actualización:** fecha/hora y usuario que la registró.
- **Estado:** `Al día` , `Desactualizada` o `Sin tasa` .
- **Historial de tasas:** vigencia, valor, observación y usuario.

Si la tasa es de un día anterior, el panel, el POS, Facturación y Tasas muestran un aviso. El aviso no bloquea la venta, pero los totales usarán la tasa vieja hasta que se actualice.

11.2 Registrar una tasa (ADMIN)

1. Consulta el valor oficial en bcv.org.ve con el botón **Consultar BCV**.
2. En **Registrar nueva tasa**, escribe:
   - **Tasa (Bs por 1 USD):** mayor que 0, hasta 4 decimales.
   - **Fecha y hora de vigencia:** no puede estar en el futuro (se toleran 5 minutos).
   - **Observación:** opcional, máximo 100 caracteres.
3. Pulsa **Registrar tasa**.

No se permite duplicar la misma fecha/hora. Si intentas guardar una fecha existente, el sistema avisa y no inserta.

11.3 Corregir una tasa (ADMIN)

1. En el historial, pulsa **Corregir** en la fila correspondiente.
2. Cambia el valor, la fecha/hora o la observación.
3. Pulsa **Guardar corrección**.

Las facturas ya emitidas conservan la tasa que tenían al momento de la venta. Corregir una tasa histórica **no** altera esos totales.

11.4 Buenas prácticas

- Registra la tasa al inicio de la jornada.

- Usa la fecha/hora real de vigencia.
- No corrijas tasas históricas salvo que sea imprescindible; si lo haces, deja una observación clara.
- Si eres CAJERO y la tasa está vencida, avisa al ADMIN antes de vender.

---

12. Mermas

Ruta: **Merma** (`/mermas`). Disponible para ADMIN y CAJERO.

Una merma es una salida de inventario por vencimiento, daño, pérdida, robo, ajuste o cualquier otro motivo. Descuenta stock y guarda el costo del momento.

12.1 Registrar una merma

1. Entra a **Merma**.
2. En **Reportar merma**, selecciona el **Producto** (solo aparecen productos activos).
3. Escribe la **Cantidad dada de baja** (mayor que 0 y no mayor que el stock).
4. Selecciona el **Motivo**:
    - Vencimiento
    - Daño
    - Pérdida
    - Robo
    - Ajuste de inventario
    - Otro
5. Agrega una **Observación** opcional (máximo 200 caracteres).
6. Pulsa **Registrar merma**.

El sistema descuenta el stock en una transacción y muestra un aviso con la cantidad y el stock restante.

12.2 Consultar

La tabla muestra fecha, producto, cantidad, motivo, usuario que reportó y observación.

- **ADMIN:** además ve **Costo unit. $** y **Pérdida $** (cantidad × costo del momento).
- **CAJERO:** no ve costos ni pérdidas.

12.3 Errores frecuentes

MENSAJE	CAUSA	SOLUCIÓN
“Selecciona un producto.”	No se eligió producto	Selecciona uno.
“La cantidad de merma debe ser mayor que cero.”	Cantidad 0 o negativa	Escribe una cantidad válida.
“La cantidad supera el stock disponible…”	Más que el stock	Ajusta la cantidad.
“El producto seleccionado no existe o está inactivo.”	Producto desactivado	Reactívalo o elige otro.

---

13. Usuarios (solo ADMIN)

Ruta: **Usuarios** (`/usuarios`).

13.1 Crear un usuario

1. En **Nuevo usuario**, completa:
   - **Nombre completo:** obligatorio, máximo 100 caracteres.
   - **Cédula:** obligatoria, formato `V-12345678` ; única.
   - **Usuario de acceso:** entre 3 y 40 caracteres; solo minúsculas, números, punto, guion o guion bajo; único.
   - **Rol:** `CAJERO – vende y consulta` o `ADMIN – acceso total` .
   - **Contraseña:** obligatoria al crear; mínimo 6 caracteres, máximo 72.
2. Pulsa **Crear usuario**.

13.2 Editar un usuario

1. Pulsa **Editar** en la fila del usuario.
2. Cambia nombre, cédula, usuario o rol.
3. Si quieres cambiar la contraseña, escríbela en **Nueva contraseña (opcional)**. Si la dejas vacía, se conserva la actual.
4. Pulsa **Guardar cambios**.

Si un ADMIN se quita su propio rol, el sistema actualiza la sesión y lo redirige al panel; pierde el acceso a Usuarios.

13.3 Restablecer contraseña

Es el mismo formulario de edición: escribe la nueva contraseña y guarda. El usuario deberá usarla en su próximo inicio de sesión.

13.4 Activar, desactivar y eliminar

- **Desactivar:** impide el inicio de sesión y cierra la sesión activa en la siguiente petición. No borra el historial. Es la opción recomendada cuando un usuario deja el negocio.
- **Reactivar:** vuelve a permitir el acceso.
- **Eliminar:** solo se permite si el usuario **no tiene facturas, tasas, mermas ni compras**. Si tiene historial, el sistema lo rechaza y sugiere desactivarlo.

13.5 Protecciones

- No puedes desactivar ni eliminar tu propia cuenta.
- No se puede dejar el sistema sin al menos un ADMIN activo.
- No se puede repetir cédula ni usuario.
- La contraseña nunca se muestra en el listado.

13.6 Buenas prácticas

- Ten al menos dos ADMIN activos.
- Usa cuentas individuales; no compartas el usuario `admin`.
- Desactiva en lugar de eliminar cuando haya historial.
- Cambia la contraseña demo inmediatamente.

---

14. Preguntas frecuentes

¿Por qué el sistema me pide la contraseña otra vez si ya había entrado?

Porque abriste `/` o `/login` con una sesión activa. El sistema cierra la sesión anterior por seguridad y exige la contraseña de nuevo. También puede ocurrir si pasaron más de 30 minutos de inactividad.

¿Por qué no veo Productos, Tasas o Usuarios?

Esos módulos son solo para ADMIN. El CAJERO tiene un menú reducido a Mi panel, Clientes, Facturación, Merma y Nueva venta.

¿Por qué no puedo eliminar un producto?

Porque tiene ventas, compras o mermas asociadas. Para conservar la trazabilidad, desactívalo. Dejará de aparecer en el POS.

¿Por qué no puedo eliminar un cliente?

Porque tiene facturas asociadas. Puedes editarlo, pero no borrarlo.

¿Por qué no puedo eliminar un usuario?

Porque tiene facturas, tasas, mermas o compras registradas. Desactívalo para bloquear el acceso sin perder el historial.

¿Por qué no puedo eliminar una factura emitida?

Primero debes anularla. Solo las facturas `ANULADA` se pueden eliminar, y solo el ADMIN puede hacerlo.

¿Por qué el botón "Descargar imagen" da error?

La extensión GD de PHP no está habilitada. El ADMIN debe habilitar `extension=gd` en `php.ini` y reiniciar Apache. Mientras tanto, usa **Descargar PDF** o **Imprimir**.

¿Por qué el PDF no muestra la URL del sistema?

Porque el PDF se genera en el servidor con `PdfFactura`, no con el diálogo "Guardar como PDF" del navegador. El botón **Imprimir** abre ese mismo PDF.

¿Por qué la tasa aparece desactualizada?

Porque la fecha de vigencia es anterior a hoy. Un ADMIN debe registrar la tasa del día en **Tasas**. Puedes seguir vendiendo, pero con la tasa anterior.

¿Puedo vender sin tasa BCV?

No. El servidor rechaza la emisión si no hay una tasa mayor que cero. El POS muestra un aviso y el botón de emisión no debe usarse hasta que el ADMIN registre la tasa.

¿Cómo busco una factura por su código de verificación?

En **Facturación**, escribe el código en **Buscar**. También puedes buscar por número de factura, control fiscal, cliente o RIF/cédula.

¿El CSV se abre mal en Excel?

El archivo usa UTF-8 con BOM, separador `;` y decimales con coma. Debe abrirse directamente en Excel en español. Si tu Excel usa otro separador, importa el archivo como CSV y elige `;`.

¿Qué hago si veo "La sesión expiró o la solicitud no es válida" (419)?

Recarga la página, vuelve a iniciar sesión y repite la operación. No envíes el formulario dos veces con una pestaña vieja.

¿Qué hago si veo "No se pudo conectar con la base de datos"?

Verifica que MySQL esté iniciado en XAMPP y que la base `de_todito_reyes` exista. Si persiste, contacta al ADMIN.

¿Puedo usar el sistema desde el celular?

La interfaz es responsive y el menú se abre con ☰, pero el POS está pensado para pantallas de escritorio. Para vender desde el celular, verifica que la tabla y el carrito sean cómodos en tu dispositivo.

¿Dónde se cambian el nombre, RIF y dirección de la empresa?

En `config/empresa.php`. Esos datos salen en el comprobante, el PDF y el PNG. Solo el ADMIN o el responsable de la instalación debe editarlos.

---

15. Glosario

TÉRMINO	SIGNIFICADO
ADMIN	Rol con acceso total: inventario, precios, usuarios, tasas, anulación y eliminación.
CAJERO	Rol operativo: vende, registra clientes, consulta facturas y reporta mermas.
BCV	Banco Central de Venezuela. La tasa se expresa en bolívares por 1 dólar.
Tasa BCV	Valor del dólar usado para convertir precios USD a Bs. Se registra manualmente.
IVA	Impuesto al Valor Agregado. Se calcula por producto según su alícuota.
IGTF	Impuesto a las Grandes Transacciones Financieras. En el sistema se aplica al 3% cuando se marca "Pago en divisa".
POS	Punto de venta: pantalla de catálogo, carrito y emisión.
SKU / Código	Código único de barras o QR del producto.
Merma	Salida de inventario por vencimiento, daño, pérdida, robo o ajuste.
Consecutivo	Número fiscal de la factura, de 6 dígitos (`000001`).
Control fiscal	Número de control de la factura (`00-000001`).
Código de verificación	Código aleatorio de 8 caracteres que acompaña la factura.
Comprobante	Vista imprimible de la factura con sus datos fiscales.
Anular	Marcar una factura como `ANULADA` y devolver el stock. No se puede revertir.
Eliminar	Borrar una factura anulada y sus líneas. Solo ADMIN.
Stock mínimo	Cantidad a partir de la cual el sistema marca stock bajo.
Stock máximo	Cantidad objetivo opcional; no bloquea ventas.
Flash	Mensaje temporal de éxito, aviso o error que se muestra una vez.
CSRF	Protección contra envíos de formularios desde otro sitio.
Sesión	Periodo autenticado; expira a los 30 minutos de inactividad.

---

16. Referencia rápida de URLs

ACCIÓN	URL
Iniciar sesión	`/` o `/login`
Panel	`/panel`
Cerrar sesión	`/logout` (POST)
Productos	`/productos`
Clientes	`/clientes`
Facturación / historial	`/facturacion`
Nueva venta (POS)	`/facturacion/nueva`
Comprobante	`/facturacion/ver/ID`
Descargar PDF	`/facturacion/pdf/ID`
Abrir PDF para imprimir	`/facturacion/pdf/ID?ver=1`
Descargar PNG	`/facturacion/imagen/ID`
Exportar resumen CSV	`/facturacion/exportar?tipo=resumen`
Exportar detalle CSV	`/facturacion/exportar?tipo=detalle`
Mermas	`/mermas`
Tasas BCV	`/tasas`
Usuarios	`/usuarios`

Los filtros del historial se pueden combinar:

```
/facturacion?desde=2026-11-01&hasta=2026-11-30&estado=EMITIDA&q=texto
```

Las URLs antiguas con `.php` (por ejemplo `productos.php`) se redirigen a la ruta limpia equivalente.

---

17. Buenas prácticas de operación

1. **Cambia las contraseñas demo** antes de la primera venta.
2. **Registra la tasa BCV al inicio del día** y avisa al equipo si cambia.
3. **No compartas usuarios.** Cada cajero debe tener su propia cuenta para que la factura y la bitácora registren al actor correcto.
4. **Revisa el stock bajo** antes de abrir caja.
5. **Usa mermas** para bajas justificadas; no edites el stock a mano para "cuadrar".
6. **Anula con criterio.** Una anulación devuelve stock y no se puede revertir.
7. **Evita eliminar facturas** salvo que sea estrictamente necesario y con respaldo.

8. **Descarga un respaldo** antes de cambios grandes (productos, usuarios, migraciones).
9. **Cierra sesión** al terminar el turno, especialmente en equipos compartidos.
10. **Reporta errores** con la URL, la hora, el usuario y el mensaje exacto.

---

18. Soporte y escalamiento

SITUACIÓN	A QUIÉN ACUDIR
No puedo entrar	ADMIN del sistema
Olvidé mi contraseña (CAJERO)	ADMIN
Olvidé la contraseña de ADMIN	Responsable técnico con acceso a consola
Tasa BCV desactualizada	ADMIN
Error al emitir una factura	ADMIN / responsable técnico
PNG no descarga	Responsable técnico (habilitar GD)
Error de base de datos	Responsable técnico
Problema de red o servidor	Responsable de infraestructura

Para reportar un problema, incluye:

- Usuario y rol.
- Fecha y hora.
- URL o módulo.
- Pasos realizados.
- Mensaje exacto (sin contraseñas).
- Si es posible, una captura de pantalla.

Fin del manual de usuario.

DOCUMENTO 2 DE 3 · INFRA

Manual de instalación — Sistema De Todito Reyes

Versión del documento: 1.0
Sistema: De Todito Reyes — Gestión y facturación
Entorno de referencia: Windows 10/11 + XAMPP (Apache 2.4, PHP 8.3, MariaDB 10.4)
Fecha: 6 de noviembre de 2026
Documentos relacionados: Manual de usuario · Revisión técnica · Diagramas de casos de uso

---

1. Introducción

Este manual describe cómo instalar, configurar, publicar y mantener el sistema **De Todito Reyes** en un servidor propio. Está dirigido a la persona responsable de la infraestructura (administrador de sistemas) y a quien vaya a desplegar el sistema por primera vez.

El sistema es una aplicación web en **PHP + MySQL** con arquitectura MVC sin framework. La única carpeta que debe quedar publicada es `public/`; el resto (`app/`, `config/`, `sql/`, `tools/`, `docs/`) contiene código interno, credenciales o scripts de recuperación y **no debe ser accesible desde el navegador**.

> **Alcance de este documento.** Las instrucciones se basan en la estructura y el código del proyecto. La revisión técnica asociada se hizo de forma estática y con verificación de sintaxis, sin ejecutar MySQL; por eso la instalación debe probarse en el servidor destino antes de ponerla en producción.

---

2. Requisitos

2.1 Hardware mínimo

RECURSO	MÍNIMO	RECOMENDADO
Procesador	2 núcleos	4 núcleos
Memoria RAM	2 GB	4 GB o más
Disco libre	1 GB	10 GB (base de datos, copias y comprobantes)
Red	LAN local	LAN con IP fija o nombre DNS interno

Para una sola caja alcanza una computadora modesta. Si varias cajas van a facturar al mismo tiempo, el servidor debe tener disco rápido y una conexión de red estable.

2.2 Software

COMPONENTE	VERSIÓN MÍNIMA	NOTAS
PHP	**8.0 o superior**	El código usa `match`, disponible desde PHP 8.0. El README del proyecto dice 7.4, pero esa versión **no** es suficiente.
MySQL / MariaDB	MySQL 8.0+ / MariaDB 10.4+	El esquema usa `CHECK`, vistas y triggers.
Apache	2.4+ con `mod_rewrite`	Necesario para las URLs limpias. XAMPP lo trae activo.
Navegador	Chrome, Edge, Firefox o Safari actualizados	No se requiere internet para operar.

> **Aviso sobre el README.** El README original indica PHP 7.4 y menciona 34 archivos PHP; el proyecto actual tiene 40 archivos y requiere PHP 8.0+. Este manual prevalece sobre el README en esos puntos.

2.3 Extensiones de PHP

EXTENSIÓN	¿OBLIGATORIA?	USO	ESTADO TÍPICO EN XAMPP
`pdo_mysql`	Sí	Conexión a la base de datos	Activa
`mbstring`	Sí	Texto y codificación	Activa
`json`	Sí	Respuestas y datos	Activa (incluida)
`fileinfo`	Recomendada	Detección de tipos de archivo	Activa
`openssl`	Recomendada	HTTPS y funciones criptográficas	Activa (incluida)
`gd`	**Para PNG**	Generar el comprobante en imagen	**Desactivada por defecto**

Sin `gd`, el sistema sigue funcionando, pero el botón **Descargar imagen** falla. El PDF y la impresión no dependen de GD.

2.4 Puertos y permisos

- Apache escucha en el puerto **80** (HTTP) y, si se configura HTTPS, en el **443**.
- MySQL/MariaDB escucha en el **3306**.
- En Windows, el usuario que ejecuta Apache necesita **lectura** sobre el proyecto y **escritura** sobre los registros de Apache y MySQL. La aplicación no escribe archivos en el proyecto: el PDF y el PNG se generan en memoria y se envían al navegador.
- En Linux, el usuario del servidor web (por ejemplo `www-data`) debe poder leer todo el proyecto y ejecutar PHP; `config/` no debe ser escribible por el servidor.

---

3. Instalación paso a paso con XAMPP

3.1 Instalar XAMPP

1. Descarga XAMPP desde `https://www.apachefriends.org/`.
2. Instala en la ruta por defecto `C:\xampp` (evita rutas con espacios o acentos).
3. Abre el **Panel de Control de XAMPP**.
4. Pulsa **Start** en **Apache** y en **MySQL**. Ambos deben quedar en verde.
5. Si Apache no arranca, revisa el puerto 80 en la sección de solución de problemas.

3.2 Copiar el proyecto

Copia la carpeta del sistema en:

```
C:\xampp\htdocs\revisionSistema
```

La estructura debe quedar así:

```
C:\xampp\htdocs\revisionSistema\
├── public\      ← única carpeta publicada
├── app\
├── config\
├── sql\
├── tools\
├── docs\
└── README.md
```

Si el proyecto está en otra ruta, ajusta todos los comandos de este manual.

3.3 Iniciar los servicios

En el Panel de Control de XAMPP:

1. **Apache** → **Start**.
2. **MySQL** → **Start**.

Comprueba que MySQL responde:

```
C:\xampp\mysql\bin\mysqladmin.exe -u root ping
```

Respuesta esperada: `mysqld is alive`.

3.4 Importar la base de datos

El archivo `sql/de_todito_reyes.sql` crea la base `de_todito_reyes`, las 12 tablas, las 4 vistas, los 4 triggers y los datos de ejemplo.

> **Advertencia importante:** el script empieza con `DROP TABLE IF EXISTS` para las 12 tablas. Si lo ejecutas sobre una base que ya tiene información, **borra todos los datos**. Úsalo solo en una instalación nueva o después de una copia de seguridad verificada.

Opción A — phpMyAdmin (recomendada para principiantes)

1. Abre `http://localhost/phpmyadmin/`.
2. Entra con usuario `root` y contraseña vacía (configuración por defecto de XAMPP).
3. Selecciona la pestaña **Importar**.
4. Pulsa **Elegir archivo** y selecciona `C:\xampp\htdocs\revisionSistema\sql\de_todito_reyes.sql`.
5. Verifica que el juego de caracteres sea **utf-8**.
6. Pulsa **Continuar** y espera el mensaje de éxito.
7. En la lista de la izquierda debe aparecer la base `de_todito_reyes` con 12 tablas y 4 vistas.

Opción B — consola

```
C:\xampp\mysql\bin\mysql.exe -u root --default-character-set=utf8mb4 <
"C:\xampp\htdocs\revisionSistema\sql\de_todito_reyes.sql"
```

Verifica la importación:

```
C:\xampp\mysql\bin\mysql.exe -u root -e "USE de_todito_reyes; SHOW TABLES;"
```

Deben aparecer, entre otras: `usuarios`, `clientes`, `productos`, `facturas`, `detalle_factura`, `tasas_cambio_bcv`, `merma_ajustes` y `bitacora_auditoria`.

Si la base ya existía

No vuelvas a importar el script completo. Aplica solo la migración pendiente (ver sección 7) y trabaja siempre sobre una copia de seguridad.

3.5 Configurar la conexión a la base de datos

Edita `config/database.php`:

```
const DB_HOST    = 'localhost';
const DB_NAME    = 'de_todito_reyes';
const DB_USER    = 'root';
const DB_PASS    = '';
const DB_CHARSET = 'utf8mb4';
```

- En XAMPP, `root` sin contraseña funciona solo en local. **No uses ese usuario en producción.**
- Si MySQL está en otro equipo, cambia `DB_HOST` por su IP o nombre y asegúrate de que acepte conexiones remotas.
- La conexión fija la zona horaria en `-04:00` (Venezuela) para que `NOW()` coincida con la fecha local.

3.6 Configurar los datos fiscales de la empresa

Edita `config/empresa.php`:

```
const EMPRESA_NOMBRE    = 'De Todito Reyes';
const EMPRESA_RIF       = 'J-00000000-0';
const EMPRESA_DIRECCION = 'Dirección fiscal pendiente';
const EMPRESA_TELEFONO  = '';
```

Estos datos aparecen en el comprobante, el PDF y el PNG. Cámbialos por los datos fiscales reales **antes de emitir la primera factura**. No hay pantalla en el sistema para editarlos: se cambian en el archivo.

3.7 Activar la extensión GD (para comprobantes PNG)

1. Abre `C:\xampp\php\php.ini` con un editor de texto.
2. Busca la línea:

   ```
   ;extension=gd
   ```

3. Quita el punto y coma:

   ```
   extension=gd
   ```

4. Guarda el archivo.
5. Reinicia **Apache** desde el Panel de Control de XAMPP.

Verifica que quedó activa:

```
C:\xampp\php\php.exe -m | findstr /i gd
```

Debe imprimir `gd`. Si no aparece, revisa que editaste el `php.ini` correcto (`C:\xampp\php\php.ini`) y que reiniciaste Apache.

3.8 Verificar extensiones y sintaxis

```
C:\xampp\php\php.exe -m
C:\xampp\php\php.exe -v
```

Comprueba que estén `pdo_mysql`, `mbstring`, `json` y, si vas a usar PNG, `gd`.

Para validar la sintaxis de todo el código:

```
cd /d "C:\xampp\htdocs\revisionSistema"
for /r app %f in (*.php) do @C:\xampp\php\php.exe -l "%f"
for %f in (public\index.php config\*.php tools\*.php) do @C:\xampp\php\php.exe -l
"%f"
```

Cada archivo debe responder `No syntax errors detected`.

---

4. Publicar el sistema con Apache

4.1 Opción A — subcarpeta de `htdocs`

Con el proyecto en `C:\xampp\htdocs\revisionSistema`, la dirección es:

```
http://localhost/revisionSistema/public/
```

Esta opción funciona sin tocar la configuración de Apache, siempre que `mod_rewrite` esté activo y `AllowOverride All` esté permitido en `htdocs` (XAMPP lo trae así). Las URLs limpias quedan como:

```
http://localhost/revisionSistema/public/panel
http://localhost/revisionSistema/public/facturacion/nueva
```

4.2 Opción B — dominio propio con VirtualHost (recomendada)

Permite una URL limpia, por ejemplo `http://toditoreyes.local/`.

1. Edita `C:\xampp\apache\conf\extra\httpd-vhosts.conf` y agrega:

```
<VirtualHost *:80>
    ServerName toditoreyes.local
    DocumentRoot "C:/xampp/htdocs/revisionSistema/public"

    <Directory "C:/xampp/htdocs/revisionSistema/public">
        Options -Indexes +FollowSymLinks
        AllowOverride All
        Require all granted
    </Directory>

    ErrorLog "logs/toditoreyes-error.log"
    CustomLog "logs/toditoreyes-access.log" combined
</VirtualHost>
```

2. Abre el Bloc de notas **como administrador** y edita:

   ```
   C:\Windows\System32\drivers\etc\hosts
   ```

   Agrega al final:

   ```
   127.0.0.1    toditoreyes.local
   ```

3. Reinicia Apache.
4. Abre `http://toditoreyes.local/`.

> **No publiques la carpeta completa del proyecto.** Si `DocumentRoot` apunta a `revisionSistema/` en lugar de `revisionSistema/public/`, el navegador podría alcanzar `config/database.php`, `sql/` o `tools/`. Los `.htaccess` internos niegan el acceso como respaldo, pero la configuración correcta es publicar solo `public/`.

4.3 Opción C — servidor embebido de PHP (solo desarrollo)

Útil para probar sin Apache. **No lo uses en producción**: es de un solo hilo y no está endurecido.

```
C:\xampp\php\php.exe -S 127.0.0.1:8000 -t "C:\xampp\htdocs\revisionSistema\public"
"C:\xampp\htdocs\revisionSistema\public\index.php"
```

Luego abre `http://127.0.0.1:8000/`.

El último argumento es el enrutador. Sin él, las URLs limpias (`/productos`, `/facturacion/nueva`) devuelven 404.

4.4 HTTPS (recomendado en producción)

El sistema no fuerza HTTPS por sí mismo. Para publicarlo fuera de la red local:

1. Activa `mod_ssl` y el archivo `httpd-ssl.conf` en `C:\xampp\apache\conf\httpd.conf` (en XAMPP suelen estar incluidos).
2. Genera o instala un certificado válido para el dominio.
3. Configura el VirtualHost en el puerto 443 con `SSLEngine on`, `SSLCertificateFile` y `SSLCertificateKeyFile`.
4. Redirige el puerto 80 al 443.
5. Fuerza que la cookie de sesión viaje solo por HTTPS. La aplicación ya define `HttpOnly` y `SameSite=Lax`, pero no `Secure`; agrégalo en `config/helpers.php`:

   ```
   session_set_cookie_params([
       'lifetime' => 0,
       'path'     => '/',
       'httponly' => true,
       'secure'   => true,      // solo con HTTPS
       'samesite' => 'Lax',
   ]);
   ```

   Si activas `secure` sin HTTPS, el navegador no enviará la cookie y **no podrás iniciar sesión**.

---

5. Estructura publicada y archivos sensibles

RUTA	¿ACCESIBLE POR HTTP?	CONTENIDO
`public/`	**Sí**	Punto de entrada, assets, `.htaccess`
`app/`	No	Controladores, modelos, vistas, generadores PDF/PNG
`config/`	No	Conexión, credenciales, helpers, datos de empresa
`sql/`	No	Esquema y migraciones
`tools/`	No	Script de recuperación de ADMIN
`docs/`	No	Documentación (puede publicarse aparte si se desea)

Cada carpeta interna tiene un `.htaccess` que responde `403`. Aun así, la defensa principal es que el `DocumentRoot` apunte a `public/`.

Comprobación rápida (deben fallar con 403 o 404):

```
http://localhost/revisionSistema/config/database.php
http://localhost/revisionSistema/sql/de_todito_reyes.sql
http://localhost/revisionSistema/tools/crear_admin.php
```

---

6. Primer acceso y puesta en marcha

6.1 Credenciales de demostración

USUARIO	CONTRASEÑA	ROL
`admin`	`admin123`	ADMIN
`mcajera`	`cajera123`	CAJERO

6.2 Cambiar las credenciales antes de operar

1. Entra como `admin`.
2. Ve a **Usuarios**.
3. Cambia la contraseña de `admin` por una clave larga y única.
4. Cambia o desactiva la cuenta `mcajera` de demostración.
5. Crea una cuenta nominal para cada cajero (no compartas usuarios).
6. Si no vas a usar las cuentas demo, desactívalas.

El sistema exige contraseñas de al menos 8 caracteres para los ADMIN creados por consola. Para el resto, aplica una política interna más estricta (12+ caracteres, sin reutilización).

6.3 Verificación posterior a la instalación

#	PRUEBA	RESULTADO ESPERADO
1	Abrir `/`	Muestra el formulario de inicio de sesión
2	Entrar con `admin` / `admin123`	Llega al panel ADMIN
3	Abrir `/panel` sin sesión	Redirige al login
4	Entrar como CAJERO	Ve **Mi panel**, sin Productos, Tasas ni Usuarios
5	Abrir `/productos` como CAJERO	Redirige a su panel con aviso
6	Registrar una tasa BCV como ADMIN	Se guarda y aparece como vigente
7	Emitir una factura de prueba	Descuenta stock y genera consecutivo
8	Abrir el comprobante	Muestra número, control y código de verificación
9	Descargar PDF	Archivo válido, sin URL ni rutas del sistema
10	Descargar PNG	Funciona solo si `gd` está activa
11	Exportar CSV	Se abre en Excel con acentos y decimales correctos
12	Cerrar sesión	Vuelve al login y `/panel` ya no es accesible
13	Abrir `config/database.php` por HTTP	403 o 404
14	Abrir `tools/crear_admin.php` por HTTP	403

Si alguna prueba falla, revisa la sección 11.

---

7. Migraciones y actualizaciones

7.1 Instalación nueva

Usa `sql/de_todito_reyes.sql`. Ya incluye la columna `codigo_verificacion` y todo el esquema actual.

7.2 Base existente anterior al código de verificación

Si la base se creó con una versión anterior y no tiene la columna `codigo_verificacion`, aplica una sola vez:

```
C:\xampp\mysql\bin\mysql.exe -u root --default-character-set=utf8mb4 de_todito_reyes
< "C:\xampp\htdocs\revisionSistema\sql\actualizacion_codigo_verificacion.sql"
```

La migración:

- agrega `codigo_verificacion` a `facturas`;
- rellena las facturas existentes con un código aleatorio de 8 caracteres;
- deja la columna como `NOT NULL` con índice único.

Antes de aplicarla, haz una copia de seguridad. Si la columna ya existe, el `ALTER TABLE` fallará; en ese caso no la ejecutes de nuevo.

7.3 Actualizar el código

1. Haz copia de seguridad de la base y de `config/`.
2. Detén Apache o pon el sistema en mantenimiento.
3. Reemplaza `app/`, `public/` y `docs/` por la versión nueva.
4. Conserva tu `config/database.php` y `config/empresa.php` (o vuelve a aplicar tus datos).
5. Revisa si la versión nueva incluye migraciones en `sql/` y applícalas en orden.
6. Ejecuta el lint de PHP (sección 3.8).
7. Reinicia Apache y recorre la lista de verificación de la sección 6.3.

Nunca sobrescribas `config/database.php` con el archivo de ejemplo si ya tiene credenciales reales.

---

8. Copias de seguridad y restauración

8.1 Copia de la base de datos

```
mkdir "C:\respaldos\de_todito_reyes"
C:\xampp\mysql\bin\mysqldump.exe -u root --single-transaction --routines --triggers
--default-character-set=utf8mb4 de_todito_reyes >
"C:\respaldos\de_todito_reyes\basedatos_2026-11-06.sql"
```

Incluye `--routines` y `--triggers` para no perder la lógica almacenada. El archivo resultante contiene datos y estructura.

8.2 Restauración

```
C:\xampp\mysql\bin\mysql.exe -u root --default-character-set=utf8mb4 -e "CREATE
DATABASE IF NOT EXISTS de_todito_reyes CHARACTER SET utf8mb4 COLLATE
utf8mb4_unicode_ci;"
C:\xampp\mysql\bin\mysql.exe -u root --default-character-set=utf8mb4 de_todito_reyes
< "C:\respaldos\de_todito_reyes\basedatos_2026-11-06.sql"
```

Si la base ya existe y quieres reemplazarla por completo, elimínala antes de restaurar. Hazlo solo con una copia verificada.

8.3 Copia de los archivos

Respalda al menos:

- `config/database.php` y `config/empresa.php` (contienen la configuración local);
- `app/` y `public/` de la versión desplegada;
- los archivos `.sql` de `sql/`;
- los registros de Apache (`C:\xampp\apache\logs\`) si se usan para auditoría.

La aplicación no guarda PDF ni PNG en disco: se generan al vuelo. No hay una carpeta `uploads/` que respaldar.

8.4 Frecuencia y retención sugeridas

TIPO	FRECUENCIA	RETENCIÓN
Base de datos completa	Diaria, al cierre	30 días
Base de datos completa	Semanal, fuera del servidor	12 semanas
Configuración y código	En cada cambio	Últimas 5 versiones
Copia externa	Mensual	12 meses

Guarda al menos una copia **fuera del mismo equipo**. Una copia en el mismo disco no protege contra fallos de hardware ni ransomware.

8.5 Prueba de restauración

Una copia no sirve si no se puede restaurar. Cada trimestre:

1. Restaura la copia en una base de prueba (`de_todito_reyes_prueba`).
2. Verifica que las facturas, el stock y los usuarios estén completos.
3. Abre el sistema apuntando a la base de prueba.
4. Elimina la base de prueba al terminar.

---

9. Seguridad y endurecimiento

9.1 Usuario de base de datos dedicado

No uses `root` en producción. Crea un usuario con permisos mínimos:

```
CREATE USER 'todito_reyes'@'localhost' IDENTIFIED BY 'UnaClaveLargaYUnica';
GRANT SELECT, INSERT, UPDATE, DELETE ON de_todito_reyes.* TO
'todito_reyes'@'localhost';
FLUSH PRIVILEGES;
```

Luego actualiza `config/database.php` con ese usuario y contraseña. La aplicación no crea ni altera tablas en tiempo de ejecución, así que no necesita `CREATE` , `ALTER` ni `DROP` . Para aplicar migraciones usa una cuenta

administrativa aparte.

Si el servidor web y MySQL están en equipos distintos, cambia `'localhost'` por la IP del servidor web y restringe el acceso por firewall.

9.2 Contraseñas y cuentas

- Cambia `admin123` y `cajera123` antes del primer uso real.
- Una cuenta por persona; no compartas el usuario `admin`.
- Desactiva las cuentas que ya no se usen; no las dejes activas "por si acaso".
- El sistema impide desactivar la propia cuenta y dejar la instalación sin ningún ADMIN activo.
- La sesión caduca a los 30 minutos de inactividad.
- No hay recuperación de contraseña por correo. Si se pierde el acceso ADMIN, usa `tools/crear_admin.php` desde la consola del servidor.

9.3 Proteger el script de recuperación

`tools/crear_admin.php` solo se ejecuta por CLI y responde `403` por HTTP. Aun así:

- No publiques `tools/` en internet.
- Si el sistema queda accesible desde fuera, elimina o mueve el script cuando termines la recuperación.
- Restringe el acceso al servidor por SSH/RDP y usa cuentas nominales.

9.4 HTTPS y cookies

- Publica el sistema con HTTPS si sale de la red local.
- Activa `secure` en la cookie de sesión cuando HTTPS esté funcionando (sección 4.4).
- No desactives `HttpOnly` ni `SameSite`.
- El sistema ya envía `Content-Security-Policy`, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff` y `Referrer-Policy: same-origin`.

9.5 phpMyAdmin

phpMyAdmin viene con XAMPP y es una puerta sensible:

- No lo publiques en internet.
- Si no lo usas, deshabilítalo o restringe el acceso por IP en `C:\xampp\apache\conf\extra\httpd-xampp.conf`.
- Cámbiale la contraseña al usuario `root` o crea un usuario administrador propio.
- Cierra la sesión de phpMyAdmin al terminar.

9.6 Permisos de archivos

Windows: mantén el proyecto en una ruta local (no en una carpeta compartida de red) y da lectura al usuario que ejecuta Apache. No des permisos de escritura sobre `config/`.

Linux:

```
sudo chown -R www-data:www-data /var/www/revisionSistema
sudo find /var/www/revisionSistema -type d -exec chmod 755 {} \;
sudo find /var/www/revisionSistema -type f -exec chmod 644 {} \;
sudo chmod 640 /var/www/revisionSistema/config/database.php
```

El `DocumentRoot` debe ser `/var/www/revisionSistema/public`.

9.7 Errores y registros

- En producción, `display_errors` debe estar **Off** y `log_errors` **On** en `php.ini`.
- Los errores técnicos se registran en el log de PHP/Apache y el usuario ve un mensaje genérico.
- Revisa periódicamente `C:\xampp\apache\logs\error.log` y el log de PHP.
- No publiques los logs en una carpeta accesible por HTTP.

Configuración recomendada en producción:

```
display_errors = Off
log_errors = On
error_log = "C:\xampp\apache\logs\php-error.log"
expose_php = Off
session.cookie_httponly = 1
session.use_strict_mode = 1
```

9.8 Red y firewall

- Si el sistema es solo para la tienda, no lo expongas a internet.
- Permite el puerto 80/443 solo desde la red local.
- No abras el puerto 3306 a internet.
- Usa una IP fija o un nombre DNS interno para el servidor.
- Si necesitas acceso remoto, usa una VPN en lugar de publicar Apache directamente.

9.9 Actualizaciones

- Mantén XAMPP, PHP y MySQL actualizados, probando primero en un entorno de staging.
- Revisa los avisos de seguridad de PHP y MariaDB/MySQL.
- Después de cada actualización, repite la lista de verificación de la sección 6.3.

---

10. Operación y mantenimiento

10.1 Tasa BCV

La tasa **no se descarga automáticamente**. Un ADMIN debe consultar el valor oficial en `https://www.bcv.org.ve/` y registrarlo en **Tasas** con su fecha de vigencia. Si la tasa es de un día anterior, el sistema muestra un aviso en el panel, el POS y el historial.

Cada factura guarda la tasa aplicada. Corregir una tasa histórica no cambia las facturas ya emitidas.

10.2 Stock y mermas

- El stock se descuenta al emitir una factura y al registrar una merma.
- La anulación de una factura devuelve las cantidades al stock.
- Revisa el aviso de **stock bajo** en el panel ADMIN.
- Registra las mermas con el motivo correcto para mantener la trazabilidad.

10.3 Espacio en disco

La base crece con las facturas, el detalle y la bitácora. Revisa el espacio libre mensualmente. Los PDF y PNG no se almacenan, pero las copias de seguridad sí ocupan disco.

10.4 Bitácora de auditoría

La tabla `bitacora_auditoria` registra eventos como `LOGIN`, `LOGIN_FALLIDO`, `LOGOUT`, `CREAR_ADMIN`, `RESET_ADMIN`, cambios de facturas y movimientos relevantes. No la borres: es la evidencia de auditoría. Si necesitas depurarla, archiva los registros antiguos antes de eliminarlos.

10.5 Rutina diaria sugerida

1. Verificar que Apache y MySQL estén activos.
2. Revisar que la tasa BCV del día esté registrada.
3. Revisar el panel: stock bajo, ventas del día y últimas facturas.
4. Al cierre, generar la copia de seguridad de la base.
5. Revisar el log de errores si hubo incidentes.

---

11. Solución de problemas

11.1 “No se pudo conectar con la base de datos”

Causas habituales:

CAUSA	SOLUCIÓN
MySQL está detenido	Inícialo desde el Panel de XAMPP
Nombre de base incorrecto	Debe ser `de_todito_reyes`
Usuario o contraseña incorrectos	Revisa `config/database.php`
El script SQL no se importó	Importa `sql/de_todito_reyes.sql`
MySQL en otro equipo	Verifica `DB_HOST`, el firewall y que MySQL escuche en red

Comprueba la conexión:

```
C:\xampp\mysql\bin\mysql.exe -u root -e "SHOW DATABASES;"
```

11.2 Error 2002 (MySQL no responde)

```
ERROR 2002 (HY000): Can't connect to MySQL server ... (10061)
```

Significa que MySQL no está escuchando. Inícialo en XAMPP y revisa el puerto 3306. Si otro programa lo ocupa, cambia el puerto en `my.ini` y en `config/database.php` (agregando `port=3307` al DSN).

11.3 Error 1045 (acceso denegado)

```
ERROR 1045 (28000): Access denied for user 'root'@'localhost'
```

La contraseña de MySQL no coincide con `DB_PASS`. Si cambiaste la clave de `root`, actualízala en `config/database.php` o crea el usuario dedicado de la sección 9.1.

11.4 Error 1049 (base desconocida)

La base `de_todito_reyes` no existe. Importa el script SQL completo o créala y vuelve a importar.

11.5 Las URLs limpias dan 404

- Confirma que `mod_rewrite` esté activo en `httpd.conf` (`LoadModule rewrite_module modules/mod_rewrite.so`).
- Confirma que el `DocumentRoot` apunte a `public/`.
- Confirma que `AllowOverride All` esté permitido para esa carpeta.
- Si usas el servidor embebido de PHP, no olvides el argumento del enrutador (`public/index.php`).

11.6 Apache no arranca o el puerto 80 está ocupado

- Otro programa (IIS, Skype, un servidor de desarrollo) puede estar usando el puerto 80.

- Cambia el puerto de Apache en `httpd.conf` (`Listen 8080`) y accede por `http://localhost:8080/`.
- Revisa `C:\xampp\apache\logs\error.log` para ver el motivo exacto.

11.7 Error 403 al abrir una carpeta interna

Es el comportamiento esperado: `config/`, `app/`, `sql/` y `tools/` niegan el acceso. Si ves 403 al abrir el sistema, revisa que estés entrando por `public/` y no por la raíz del proyecto.

11.8 Error 500 o página en blanco

1. Revisa `C:\xampp\apache\logs\error.log`.
2. Activa temporalmente `display_errors` en un entorno de prueba (nunca en producción).
3. Ejecuta el lint de PHP (sección 3.8).
4. Verifica que PHP sea 8.0 o superior.
5. Comprueba que las extensiones `pdo_mysql` y `mbstring` estén activas.

11.9 "Descargar imagen" falla

Falta la extensión GD. Sigue la sección 3.7, guarda `php.ini` y reinicia Apache. Verifica con `php -m | findstr /i gd`.

11.10 Error 419 "La sesión expiró o la solicitud no es válida"

El token CSRF no coincide o la sesión caducó. Recarga la página, vuelve a iniciar sesión y repite la acción. No envíes formularios con la pestaña abierta durante horas.

11.11 Los acentos se ven mal

- La base debe usar `utf8mb4`.
- El archivo SQL debe importarse con `--default-character-set=utf8mb4` o con "utf-8" seleccionado en phpMyAdmin.
- No edites los archivos PHP con un editor que guarde en ANSI/Windows-1252; usa UTF-8 sin BOM.
- Verifica que Apache envíe `charset=utf-8` (el sistema declara la codificación en el HTML).

11.12 La hora no coincide con Venezuela

La conexión fija `-04:00` y PHP usa `America/Caracas`. Si la hora del servidor está mal, corrígela en Windows (`Configuración → Hora e idioma`) o en Linux (`timedatectl`). La aplicación no puede corregir un reloj desajustado del sistema operativo.

11.13 No puedo entrar como ADMIN

1. Verifica que el usuario esté activo en la base.
2. Usa el script de consola:

```
cd /d "C:\xampp\htdocs\revisionSistema"
C:\xampp\php\php.exe tools\crear_admin.php --listar
C:\xampp\php\php.exe tools\crear_admin.php --resetear --usuario=admin --
clave=NuevaClave123 --si
```

3. Si el script dice que no hay conexión, revisa MySQL y `config/database.php`.
4. Si el sistema está en producción, elimina o protege el script después de usarlo.

11.14 El PDF se descarga vacío o da error

- Verifica que la factura exista y que el ID sea numérico.
- Revisa el log de PHP: un error de memoria o de codificación puede romper la generación.
- El PDF se genera en el servidor; no depende de Chrome ni de librerías externas.
- Si el problema persiste, compara con una factura de una sola línea para descartar un caso extremo.

11.15 El CSV se abre mal en Excel

El sistema exporta UTF-8 con BOM, separador `;` y decimales con coma. Si Excel abre todo en una columna, revisa la configuración regional de Windows (separador de listas). No cambies el archivo a mano antes de abrirlo.

---

12. Desinstalación

1. Genera una copia de seguridad si necesitas conservar los datos.
2. Detén Apache y MySQL.
3. Elimina la carpeta `C:\xampp\htdocs\revisionSistema`.
4. Elimina la base de datos:

```
C:\xampp\mysql\bin\mysql.exe -u root -e "DROP DATABASE IF EXISTS
de_todito_reyes;"
```

5. Si creaste un VirtualHost, elimina el bloque de `httpd-vhosts.conf` y la línea de `hosts`.
6. Reinicia Apache.
7. Borra las copias de seguridad solo cuando ya no las necesites y según tu política de retención.

> El `DROP DATABASE` es irreversible. Confirma dos veces que estás en el servidor correcto.

---

13. Anexos

A. Comandos útiles

```
:: Versión de PHP y extensiones
C:\xampp\php\php.exe -v
C:\xampp\php\php.exe -m

:: Estado de MySQL
C:\xampp\mysql\bin\mysqladmin.exe -u root ping

:: Importar base nueva (borra datos existentes)
C:\xampp\mysql\bin\mysql.exe -u root --default-character-set=utf8mb4 <
"C:\xampp\htdocs\revisionSistema\sql\de_todito_reyes.sql"

:: Copia de seguridad
C:\xampp\mysql\bin\mysqldump.exe -u root --single-transaction --routines --triggers
--default-character-set=utf8mb4 de_todito_reyes >
"C:\respaldos\de_todito_reyes\basedatos.sql"

:: Restaurar
C:\xampp\mysql\bin\mysql.exe -u root --default-character-set=utf8mb4 de_todito_reyes
< "C:\respaldos\de_todito_reyes\basedatos.sql"

:: Servidor embebido de desarrollo
C:\xampp\php\php.exe -S 127.0.0.1:8000 -t "C:\xampp\htdocs\revisionSistema\public"
"C:\xampp\htdocs\revisionSistema\public\index.php"

:: Recuperación de ADMIN
cd /d "C:\xampp\htdocs\revisionSistema"
C:\xampp\php\php.exe tools\crear_admin.php --listar
C:\xampp\php\php.exe tools\crear_admin.php --crear --cedula=V-99999999 --
nombre="Admin Respaldo" --usuario=admin2 --clave=ClaveSegura123 --si
C:\xampp\php\php.exe tools\crear_admin.php --resetear --usuario=admin --
clave=NuevaClave123 --si
```

B. Lista de verificación de producción

Antes de declarar el sistema en producción, confirma cada punto:

- [ ] PHP 8.0+ con `pdo_mysql`, `mbstring`, `json` y `gd` activas.
- [ ] MySQL/MariaDB activo y base `de_todito_reyes` importada.
- [ ] `config/database.php` con un usuario dedicado, no `root`.
- [ ] `config/empresa.php` con nombre, RIF, dirección y teléfono reales.
- [ ] `DocumentRoot` apuntando a `public/`.
- [ ] `mod_rewrite` activo y `AllowOverride All` en la carpeta publicada.

- [ ] HTTPS configurado (si el sistema sale de la red local).
- [ ] Cookie de sesión con `Secure` cuando HTTPS esté activo.
- [ ] Contraseñas demo cambiadas y cuentas innecesarias desactivadas.
- [ ] `tools/crear_admin.php` protegido o eliminado.
- [ ] phpMyAdmin restringido o deshabilitado.
- [ ] `display_errors = Off` y `log_errors = On`.
- [ ] Copia de seguridad automática configurada y **probada**.
- [ ] Lista de verificación de la sección 6.3 completada.
- [ ] Responsable de soporte y procedimiento de escalamiento definidos.

C. Valores por defecto que debes cambiar

ELEMENTO	VALOR POR DEFECTO	ACCIÓN
Usuario MySQL	`root` sin contraseña	Crear usuario dedicado
Contraseña `admin`	`admin123`	Cambiar
Contraseña `mcajera`	`cajera123`	Cambiar o desactivar
RIF de la empresa	`J-00000000-0`	Reemplazar por el real
Dirección fiscal	`Dirección fiscal pendiente`	Reemplazar por la real
Teléfono	Vacío	Completar
Extensión GD	Desactivada	Activar para PNG
HTTPS	No configurado	Configurar en producción

D. Contacto y soporte

Este manual no define un canal de soporte corporativo. Antes de entregar el sistema, registra:

- nombre y contacto del responsable técnico;
- horario de atención;
- procedimiento para reportar incidentes;
- ubicación de las copias de seguridad;
- persona autorizada para restablecer contraseñas ADMIN.

Documento elaborado a partir del código, el esquema SQL y la configuración del proyecto. Las rutas y versiones corresponden al entorno de referencia indicado al inicio; ajústalas si tu instalación es distinta.

DOCUMENTO 3 DE 3 · AUDITORÍA

Revisión técnica — Sistema De Todito Reyes

Proyecto: Sistema de gestión y facturación "De Todito Reyes"
Ubicación revisada: `C:\xampp\htdocs\revisionSistema`
Fecha de revisión: 6 de noviembre de 2026
Tipo de revisión: estática (código, base de datos, configuración y documentación)
Entorno: Windows, XAMPP, PHP 8.3.36, MariaDB/MySQL de XAMPP
Documentos relacionados: Manual de usuario · Manual de instalación · Diagramas de casos de uso

---

1. Resumen ejecutivo

El sistema está construido como una aplicación MVC en PHP sin framework, con PDO y MySQL/MariaDB. La separación entre `public/` (raíz web) y `app/`, `config/`, `sql/` y `tools/` es correcta y reduce la exposición de código interno. La lógica de facturación es la parte más cuidada: usa transacciones, bloqueos `FOR UPDATE`, `GET_LOCK` para el consecutivo, recálculo de precios en el servidor y auditoría mediante triggers.

La revisión encontró **dos riesgos críticos** y varios riesgos altos que deben atenderse antes de usar el sistema en producción:

1. Las credenciales de demostración siguen activas y la conexión usa `root` sin contraseña.
2. El script de instalación elimina las 12 tablas existentes (`DROP TABLE`) sin confirmación.

Además, el sistema **no fuerza HTTPS**, la cookie de sesión no usa `Secure`, no hay límite de intentos de login, la auditoría solo cubre autenticación y facturas, y la documentación contiene afirmaciones desactualizadas (por ejemplo, dice que hay 34 archivos PHP cuando hay 40, y que el token CSRF nunca se conserva cuando tres controladores sí lo guardan en sesión).

La calidad interna del código es buena para un proyecto académico/pequeño: no se encontraron inyecciones SQL ni XSS evidentes, y las reglas de autorización se aplican en el servidor, no solo en la interfaz. Con las correcciones indicadas, el sistema puede considerarse una base sólida para un negocio pequeño.

Valoración global

DIMENSIÓN	VALORACIÓN	COMENTARIO
Arquitectura y organización	Buena	MVC claro, raíz web aislada, autoload simple.
Seguridad de aplicación	Aceptable con reservas	Buenas bases (PDO, CSRF, escape, roles), pero faltan controles de producción.
Seguridad de infraestructura	Insuficiente para producción	Sin HTTPS, `root` sin clave, credenciales demo.
Consistencia funcional	Buena	Reglas de negocio coherentes y transaccionales.
Documentación	Buena pero desactualizada	Muy completa, con desfases concretos.
Pruebas	Limitada	Solo `php -l`; no hay pruebas automatizadas ni CI.
Mantenibilidad	Media	Código legible, pero sin framework, tests ni migraciones formales.

---

2. Alcance y metodología

2.1 Alcance

Se revisaron:

- Los 40 archivos PHP del proyecto (controladores, modelos, vistas, configuración, herramientas y punto de entrada).
- El esquema SQL `sql/de_todito_reyes.sql` y la migración `sql/actualizacion_codigo_verificacion.sql`.
- Los archivos `.htaccess` de `public/`, `app/`, `config/`, `sql/` y `tools/`.
- El JavaScript de `public/assets/js/` y la hoja de estilos.
- El `README.md` del proyecto.
- La configuración de PHP y extensiones del entorno XAMPP.

2.2 Metodología

1. Lectura completa del código y del esquema.
2. Verificación de sintaxis con `php -l` sobre los 40 archivos.
3. Verificación de extensiones PHP cargadas.
4. Comprobación del estado del servidor MySQL.
5. Revisión manual de controles de seguridad: autenticación, sesión, CSRF, autorización, validación de entrada, escape de salida, consultas SQL, manejo de errores, auditoría, archivos y configuración.
6. Contraste entre lo que afirma el `README.md` y lo que hace el código.

2.3 Limitaciones

- **MySQL no estaba en ejecución** durante la revisión (`Can't connect to server on 'localhost' (10061)`), por lo que no se pudieron repetir pruebas de integración, concurrencia ni flujos completos en navegador.
- No se dispone de un entorno de staging ni de datos reales.
- No se hicieron pruebas de carga, penetración externa ni análisis de dependencias (el proyecto no usa Composer).
- Las afirmaciones del `README.md` sobre pruebas realizadas no pudieron reproducirse en este entorno; se contrastaron con el código, no con ejecución real.

2.4 Verificaciones ejecutadas

VERIFICACIÓN	RESULTADO
Archivos PHP analizados	**40**
`php -l`	**40/40 sin errores de sintaxis**
PHP	**8.3.36**
`pdo_mysql`	Habilitada
`mbstring`	Habilitada
`json`	Habilitada
`fileinfo`	Habilitada
`openssl`	Habilitada
`gd`	**Deshabilitada** (`;extension=gd` en `php.ini`)
Servidor MySQL	**Detenido** durante la revisión
Pruebas automatizadas	No existen
CI/CD	No existe

---

3. Arquitectura y stack

3.1 Stack

- **Lenguaje:** PHP 8.x (probado con 8.3.36). El README declara 7.4, pero el uso de `match` exige **PHP 8.0+** (ver AL-07).
- **Base de datos:** MySQL 8.0+ / MariaDB 10.4+.
- **Acceso a datos:** PDO con consultas preparadas reales (`ATTR_EMULATE_PREPARES = false`).
- **Frontend:** HTML, CSS y JavaScript propios, sin CDN ni frameworks.
- **Servidor web:** Apache con `mod_rewrite` o el servidor embebido de PHP para desarrollo.
- **Generación de documentos:** PDF nativo (`PdfFactura`) y PNG con GD (`ImagenFactura`).

3.2 Estructura

```
revisionSistema/
├── public/          ← única raíz web
│   ├── index.php    ← front controller y enrutador
│   ├── .htaccess    ← reescritura a index.php
│   └── assets/      ← CSS y JS
├── app/
│   ├── core/        ← BaseController, PdfFactura, ImagenFactura, fuentes
│   ├── controladores/
│   ├── modelos/
│   └── vistas/
├── config/          ← bootstrap, PDO, empresa, helpers
├── sql/             ← esquema, datos demo y migración
├── tools/           ← recuperación de ADMIN por consola
└── docs/            ← esta revisión y los manuales
```

3.3 Flujo de una petición

1. Apache reescribe la URL a `public/index.php` (o el servidor embebido usa `index.php` como router).
2. `config/bootstrap.php` carga helpers, base de datos y datos de empresa.
3. El enrutador resuelve la ruta y llama al método del controlador.
4. El controlador exige sesión/rol, valida CSRF y delega en el modelo.
5. El modelo usa PDO y transacciones cuando corresponde.
6. La vista escapa la salida con `e()` y se renderiza dentro del layout.

3.4 Modelo de datos

El esquema contiene **12 tablas** y **4 vistas**:

- Tablas: `categorias`, `proveedores`, `usuarios`, `clientes`, `productos`, `compras_proveedor`, `detalle_compra`, `tasas_cambio_bcv`, `facturas`, `detalle_factura`, `merma_ajustes`, `bitacora_auditoria`.
- Vistas: `v_tasa_vigente`, `v_stock_bajo`, `v_libro_ventas`, `v_movimientos_producto`.
- Triggers: auditoría de facturas (`INSERT` / `UPDATE`), bloqueo de stock negativo y validación de merma.

Las relaciones usan `InnoDB`, `utf8mb4` y claves foráneas con `RESTRICT` en los historiales, lo que protege la trazabilidad.

---

4. Fortalezas encontradas

1. **Raíz web aislada.** Solo `public/` se publica; `app/`, `config/`, `sql/` y `tools/` quedan fuera del alcance HTTP y además tienen `.htaccess` de respaldo.

2. **Consultas preparadas reales.** `PDO::ATTR_EMULATE_PREPARES = false` y marcadores nombrados; no se concatena entrada del usuario en SQL.
3. **CSRF correcto.** `csrf_verify()` rechaza tokens vacíos, ausentes o manipulados con `hash_equals`; el login sin token devuelve 419.
4. **Contraseñas seguras.** `password_hash()` / `password_verify()` con `PASSWORD_DEFAULT` y rehash automático.
5. **Sesión endurecida.** `session.use_strict_mode`, regeneración de ID al iniciar sesión, `HttpOnly`, `SameSite=Lax`, cierre por inactividad a los 30 minutos y revalidación de la cuenta en cada petición.
6. **Autorización en servidor.** `require_login()` y `require_admin()` protegen cada módulo; el CAJERO no puede editar/eliminar clientes, anular/eliminar facturas, gestionar productos, tasas ni usuarios aunque manipule la URL.
7. **Escape de salida sistemático.** Las vistas usan `e()` (`htmlspecialchars` con `ENT_QUOTES`) para datos de usuario.
8. **Cabeceras de seguridad.** CSP, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: same-origin` y `Cache-Control: no-store` en páginas autenticadas.
9. **Facturación transaccional.** Recálculo en servidor, `SELECT ... FOR UPDATE`, descuento de stock en la misma transacción, `GET_LOCK` para el consecutivo y reintentos ante colisión.
10. **Auditoría de facturas.** Triggers que registran emisión y anulación, incluido el usuario que anula mediante `@auditoria_usuario`.
11. **Exportación CSV robusta.** BOM UTF-8, separador `;`, formato venezolano y neutralización de fórmulas para Excel.
12. **Documentos sin dependencias.** PDF y PNG se generan en el servidor, sin CDN ni librerías externas.
13. **Formato local correcto.** Zona horaria `America/Caracas`, `SET time_zone = '-04:00'`, moneda y cantidades con formato venezolano.
14. **Recuperación de acceso controlada.** `tools/crear_admin.php` solo funciona por CLI y conserva `.htaccess` de respaldo.

---

5. Hallazgos por severidad

> **Criterio de severidad**
>
> - **Crítico:** permite comprometer el sistema o perder datos de forma inmediata.
> - **Alto:** riesgo relevante de seguridad, integridad o continuidad; debe corregirse antes de producción.
> - **Medio:** debilidad que aumenta la superficie de ataque o dificulta la operación.
> - **Bajo:** mejora de calidad, documentación o mantenibilidad.

5.1 Resumen

ID	SEVERIDAD	HALLAZGO	UBICACIÓN PRINCIPAL
CR-01	Crítico	Credenciales demo activas y MySQL `root` sin contraseña	`sql/de_todito_reyes.sql`, `config/database.php`
CR-02	Crítico	Script de instalación destructivo (`DROP TABLE`)	`sql/de_todito_reyes.sql`
AL-01	Alto	Sin HTTPS, sin `Secure` en cookie y sin HSTS	`config/helpers.php`, despliegue
AL-02	Alto	Sin límite de intentos ni bloqueo de login	`LoginController.php`
AL-03	Alto	Auditoría incompleta fuera de login y facturas	controladores y modelos
AL-04	Alto	Eliminación física de facturas anuladas	`FacturaModel::eliminar()`
AL-05	Alto	GD deshabilitada: PNG del comprobante falla	`php.ini`, `ImagenFactura.php`
AL-06	Alto	Documentación desactualizada en puntos de seguridad	`README.md`
AL-07	Alto	El README declara PHP 7.4, pero el código usa `match` (PHP 8.0+)	`README.md`, controladores
ME-01	Medio	`old_producto`, `old_cliente` y `old_tasa` guardan el token CSRF	controladores
ME-02	Medio	Política de contraseñas débil (mínimo 6, sin complejidad)	`UsuariosController.php`
ME-03	Medio	El mensaje de login permite enumerar usuarios inactivos	`LoginController.php`
ME-04	Medio	Corregir una tasa no actualiza el usuario que la registró	`TasaModel::actualizar()`
ME-05	Medio	Sin pruebas automatizadas ni CI	proyecto
ME-06	Medio	Sin estrategia de respaldos automatizados	operación
ME-07	Medio	CSP permite estilos inline y no hay `upgrade-insecure-requests`	`helpers.php`
BA-01	Bajo	La tasa “vigente” puede incluir una tasa futura por tolerancia de 5 min	`TasaModel::vigente()`
BA-02	Bajo	El servidor embebido de PHP no es apto para producción	documentación
BA-03	Bajo	Se mantienen URLs legacy y código de vista no usado	router y vistas
BA-04	Bajo	Conteo de archivos PHP y nombres de usuarios desactualizados	`README.md`
BA-05	Bajo	`casos_uso_general.puml` quedó como artefacto alternativo	`docs/casos-de-uso/`

5.2 Detalle de hallazgos

CR-01 — Credenciales de demostración activas y conexión como `root` sin contraseña

Evidencia

- `sql/de_todito_reyes.sql` crea `admin` / `admin123` y `mcajera` / `cajera123`.
- `config/database.php` usa:

```
const DB_USER = 'root';
const DB_PASS = '';
```

- El README recomienda cambiarlas, pero no hay un cambio forzado ni una advertencia bloqueante al primer inicio.

Impacto

Cualquier persona con acceso a la URL puede entrar como ADMIN con credenciales públicas. Si MySQL está expuesto en la red, cualquiera puede conectarse como `root` sin contraseña y leer, modificar o borrar toda la base.

Recomendación

1. Cambiar las contraseñas de `admin` y `mcajera` antes de publicar.
2. Eliminar o desactivar las cuentas demo que no se usen.
3. Crear un usuario MySQL dedicado (`de_todito_reyes_app`) con permisos solo sobre la base del sistema.
4. No usar `root` en la aplicación.
5. Añadir una comprobación de primer inicio que obligue a cambiar la contraseña demo.

Prioridad: inmediata.

CR-02 — Script de instalación destructivo

Evidencia

`sql/de_todito_reyes.sql` contiene:

```
SET FOREIGN_KEY_CHECKS = 0;
DROP TABLE IF EXISTS bitacora_auditoria;
DROP TABLE IF EXISTS merma_ajustes;
...
DROP TABLE IF EXISTS categorias;
SET FOREIGN_KEY_CHECKS = 1;
```

Impacto

Si se ejecuta sobre una base existente para “actualizar” el sistema, borra todos los datos sin confirmación. Es un riesgo alto de pérdida de información en producción.

Recomendación

1. Separar el script en:
   - `crear_esquema.sql` (solo `CREATE TABLE IF NOT EXISTS`).
   - `datos_demo.sql` (opcional).
   - `migraciones/` para cambios incrementales.
2. Añadir una confirmación explícita o un modo `--force` en la herramienta de instalación.
3. Documentar con letra grande que el script actual es solo para una instalación nueva.
4. Automatizar un respaldo antes de cualquier importación.

Prioridad: inmediata.

AL-01 — Sin HTTPS, sin `Secure` en la cookie y sin HSTS

Evidencia

`config/helpers.php` configura la cookie así:

```
session_set_cookie_params([
    'lifetime' => 0,
    'path'     => '/',
    'httponly' => true,
    'samesite' => 'Lax',
]);
```

No se define `'secure' => true`, no se fuerza la redirección a HTTPS y no se envía `Strict-Transport-Security`.

Impacto

En una red no confiable, las credenciales y la cookie de sesión pueden interceptarse. Un atacante podría secuestrar la sesión y operar como el usuario.

Recomendación

1. Publicar el sistema únicamente detrás de HTTPS (certificado válido, idealmente Let's Encrypt).
2. Añadir `'secure' => true` cuando `HTTPS` esté activo.
3. Redirigir HTTP → HTTPS a nivel de Apache o balanceador.
4. Enviar `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
5. Mantener `HttpOnly` y `SameSite=Lax` (o `Strict` si la operación lo permite).

Prioridad: antes de producción.

AL-02 — Sin límite de intentos ni bloqueo de login

Evidencia

`LoginController::index()` valida usuario y contraseña, pero no cuenta intentos fallidos, no aplica retraso, no bloquea la cuenta ni la IP y no usa CAPTCHA. `LOGIN_FALLIDO` se registra en la bitácora, pero no se consulta para limitar.

Impacto

Permite ataques de fuerza bruta o *password spraying* contra `admin` y otros usuarios. La contraseña mínima de 6 caracteres agrava el riesgo.

Recomendación

1. Limitar intentos por combinación IP + usuario (por ejemplo, 5 intentos en 15 minutos).
2. Aplicar retraso exponencial o bloqueo temporal.
3. Alertar al ADMIN tras varios fallos.
4. Considerar CAPTCHA tras 3 fallos.
5. Registrar y monitorizar los eventos `LOGIN_FALLIDO`.

Prioridad: alta.

AL-03 — Auditoría incompleta

Evidencia

- `UsuarioModel::registrarBitacora()` se usa para `LOGIN`, `LOGIN_FALLIDO`, `LOGOUT`, `CREAR_ADMIN` y `RESET_ADMIN`.
- Los triggers de `facturas` registran emisión y anulación.
- No hay registros equivalentes para altas/ediciones/bajas de productos, clientes, usuarios, tasas o mermas.

Impacto

Ante un incidente o un error operativo no se puede saber quién cambió un precio, eliminó un cliente, desactivó un usuario o corrigió una tasa.

Recomendación

1. Crear un servicio de auditoría único (`Auditoria::registrar()`).
2. Registrar en cada operación CRUD: usuario, acción, entidad, ID, datos anteriores y nuevos (sin secretos), IP y fecha.
3. Añadir triggers o tablas de historial para precios y tasas.
4. Incluir un visor de bitácora para el ADMIN.

Prioridad: alta.

AL-04 — Eliminación física de facturas anuladas

Evidencia

`FacturaModel::eliminar()` borra la factura y sus líneas:

```
DELETE FROM detalle_factura WHERE id_factura = :id
DELETE FROM facturas WHERE id_factura = :id
```

Solo permite facturas `ANULADA`, pero las elimina definitivamente.

Impacto

Un documento fiscal anulado sigue siendo parte de la historia fiscal. Borrarlo puede dificultar una fiscalización, una auditoría interna o una conciliación. Aunque el consecutivo no se reutiliza (se conserva en la bitácora), el comprobante y su detalle desaparecen.

Recomendación

1. Sustituir el borrado físico por borrado lógico (`eliminada = 1`, `fecha_eliminacion`, `id_usuario_elimina`) o por archivado.
2. Restringir la eliminación a un rol superior y exigir motivo.
3. Conservar el detalle y el PDF/PNG de la factura anulada.
4. Definir una política de retención legal con asesoría fiscal.

Prioridad: alta.

AL-05 — GD deshabilitada: el PNG del comprobante falla

Evidencia

- `php -i` / `extension_loaded('gd')` devuelve `false`.
- `C:\xampp\php\php.ini` tiene `;extension=gd`.
- `ImagenFactura::__construct()` lanza una excepción si no existen `imagettftext` o `imagepng`.

Impacto

El botón **Descargar imagen** no funciona; el usuario recibe un aviso de error. El PDF y la impresión siguen funcionando.

Recomendación

1. Habilitar `extension=gd` en `php.ini`.
2. Reiniciar Apache.
3. Verificar con `php -m | findstr gd`.
4. Añadir una comprobación en el panel de salud o en la instalación.

5. Si no se puede habilitar GD, ocultar el botón y documentar la limitación.

Prioridad: alta (funcionalidad anunciada).

AL-06 — Documentación desactualizada en puntos de seguridad

Evidencia

- El `README.md` dice "Los 34 archivos PHP pasan `php -l`"; el conteo real es **40**.
- El README afirma que los formularios rechazados "nunca" conservan el token CSRF; sin embargo:
  - `ProductosController` guarda `$_POST` completo en `old_producto`.
  - `ClientesController` guarda `$_POST` completo en `old_cliente`.
  - `TasasController` guarda `$_POST` completo en `old_tasa`.
- El README menciona usuarios `mcajeraw`, `mcajera` y `cajero2`; el SQL solo crea `admin` y `mcajera`.

Impacto

La documentación transmite una garantía de seguridad que el código no cumple y dificulta la operación (conteos y cuentas incorrectas).

Recomendación

1. Corregir el conteo y los nombres.
2. Ajustar la afirmación sobre CSRF o corregir el código (ver ME-01).
3. Añadir una sección "Última verificación" con fecha, entorno y comandos.
4. Revisar el README en cada release.

Prioridad: alta (por la afirmación de seguridad).

AL-07 — Compatibilidad de PHP declarada incorrectamente

Evidencia

- El `README.md` indica "PHP 7.4 o superior".
- `FacturacionController.php` y `UsuariosController.php` usan la expresión `match`, introducida en **PHP 8.0**.
- El proyecto se probó con PHP **8.3.36**.

Impacto

Un servidor con PHP 7.4 produciría un error de sintaxis al cargar los controladores y el sistema no funcionaría. La instalación podría fallar sin un mensaje claro.

Recomendación

1. Declarar PHP **8.0+** como requisito mínimo (recomendado 8.2/8.3).

2. Añadir una comprobación de versión en `config/bootstrap.php` o en el instalador.
3. Actualizar el README y el manual de instalación.
4. Si se necesita PHP 7.4, sustituir `match` por `switch` / `if`.

Prioridad: alta (bloquea instalaciones).

ME-01 — Los formularios guardan el token CSRF en sesión

Evidencia

```
// ProductosController.php
$_SESSION['old_producto'] = $_POST;

// ClientesController.php
$_SESSION['old_cliente'] = $_POST;

// TasasController.php
$_SESSION['old_tasa'] = $_POST;
```

`$_POST` incluye `csrf`. `UsuariosController` sí lo elimina:

```
unset($old['password'], $old['csrf']);
```

Impacto

El token CSRF queda almacenado en la sesión del servidor y se reinyecta en el formulario. No es una vulnerabilidad crítica por sí sola, pero contradice la documentación, aumenta la exposición innecesaria y dificulta la rotación de tokens.

Recomendación

Guardar solo los campos del formulario, con una lista blanca:

```
$_SESSION['old_producto'] = [
    'codigo_qr_barras' => $_POST['codigo_qr_barras'] ?? '',
    'nombre_producto'  => $_POST['nombre_producto'] ?? '',
    // ...
];
```

Nunca guardar `csrf`, contraseñas ni tokens.

Prioridad: media.

ME-02 — Política de contraseñas débil

Evidencia

- `UsuariosController::validarClave()` exige mínimo **6** caracteres y máximo 72, sin complejidad.
- `tools/crear_admin.php` exige mínimo **8** para ADMIN.
- El login no exige cambio de contraseña en el primer ingreso.

Impacto

Contraseñas como `123456` son aceptadas. Combinado con la ausencia de rate limiting, el riesgo de fuerza bruta aumenta.

Recomendación

1. Exigir mínimo 12 caracteres para ADMIN y 10 para CAJERO.
2. Validar contra listas de contraseñas comunes.
3. Permitir frases de paso y no imponer reglas de composición obsoletas.
4. Forzar cambio en el primer inicio y tras un reseteo.
5. Considerar MFA para ADMIN.

Prioridad: media.

ME-03 — El mensaje de login permite enumerar usuarios inactivos

Evidencia

`LoginController.php`:

```
'Usuario o contraseña incorrectos, o el usuario está inactivo.'
```

Impacto

Un atacante puede distinguir si un usuario existe pero está inactivo, o al menos obtener una pista adicional. No revela la contraseña, pero facilita la enumeración.

Recomendación

Usar un mensaje genérico: “Usuario o contraseña incorrectos.” y registrar el motivo real solo en la bitácora.

Prioridad: media.

ME-04 — Corregir una tasa no actualiza el usuario que la registró

Evidencia

`TasaModel::actualizar()` actualiza `tasa_bcv_ves`, `fecha_vigencia` y `observacion`, pero no `id_usuario`. La pantalla muestra "Registrada por" con el usuario original.

Impacto

La atribución de una corrección es incorrecta; no se sabe quién modificó la tasa. Es un problema de auditoría.

Recomendación

Añadir `id_usuario_actualiza` y `fecha_actualizacion`, o registrar la corrección en la bitácora con el usuario de la sesión.

Prioridad: media.

ME-05 — Sin pruebas automatizadas ni CI

Evidencia

No hay carpeta `tests/`, `phpunit.xml`, `composer.json` ni pipeline. La única verificación es `php -l`.

Impacto

Los cambios en facturación, stock o permisos pueden romper reglas críticas sin detección temprana. El README describe muchas pruebas manuales, pero no son reproducibles.

Recomendación

1. Añadir PHPUnit para modelos y helpers.
2. Crear pruebas de integración con una base de datos de prueba.
3. Probar: emisión, anulación, stock, IVA/IGTF, permisos, CSRF, login, CSV.
4. Configurar un pipeline (GitHub Actions u otro) con `php -l` y pruebas.
5. Añadir pruebas de regresión para los hallazgos corregidos.

Prioridad: media.

ME-06 — Sin estrategia de respaldos automatizados

Evidencia

No hay scripts de respaldo, tareas programadas ni documentación operativa de restauración.

Impacto

Un fallo de disco, un error humano o el script destructivo pueden causar pérdida total de datos.

Recomendación

1. Programar `mysqldump` diario con retención (7 diarios, 4 semanales, 12 mensuales).
2. Respaldar también `config/` y los archivos de facturas si se conservan.

3. Probar la restauración periódicamente.
4. Guardar copias fuera del servidor.
5. Documentar el procedimiento en el manual de instalación.

Prioridad: media.

ME-07 — CSP permite estilos inline y no hay `upgrade-insecure-requests`

Evidencia

```
"style-src 'self' 'unsafe-inline'; script-src 'self'"
```

Impacto

`'unsafe-inline'` en estilos reduce la protección de la CSP, aunque el riesgo principal sería un ataque de inyección de estilos. No hay `upgrade-insecure-requests`, útil cuando se migre a HTTPS.

Recomendación

1. Mover los estilos inline a `estilos.css`.
2. Eliminar `'unsafe-inline'` de `style-src`.
3. Añadir `upgrade-insecure-requests` al migrar a HTTPS.
4. Mantener `script-src 'self'` sin `unsafe-inline`.

Prioridad: media.

BA-01 — La tasa “vigente” puede incluir una tasa futura

Evidencia

`TasaModel::vigente()` ordena por `fecha_vigencia DESC` sin filtrar `fecha_vigencia <= NOW()`. La validación permite hasta 5 minutos en el futuro (`now +5 minutes`).

Impacto

Una tasa registrada para dentro de 3 minutos se usa antes de tiempo. El impacto es menor, pero puede confundir la operación.

Recomendación

Añadir `WHERE fecha_vigencia <= NOW()` a `vigente()` y eliminar la tolerancia de 5 minutos o reducirla.

Prioridad: baja.

BA-02 — El servidor embebido de PHP no es apto para producción

Evidencia

El README documenta `php -S` para desarrollo. Es correcto, pero no se advierte con suficiente claridad que es monohilo y no debe usarse en producción.

Impacto

Si se publica con `php -S`, el rendimiento y la concurrencia serán limitados.

Recomendación

Usar Apache/Nginx con PHP-FPM en producción y dejar `php -S` solo para desarrollo.

Prioridad: baja.

BA-03 — URLs legacy y código de vista no usado

Evidencia

- El router mantiene redirecciones para `productos.php`, `facturacion.php?accion=...`, etc.
- `app/vistas/productos/index.php` tiene una rama `if (!is_admin())` que nunca se ejecuta porque `ProductosController` exige ADMIN.

Impacto

Deuda técnica y confusión; no es un riesgo funcional.

Recomendación

Mantener las redirecciones mientras haya enlaces externos, pero documentar su fecha de retiro. Eliminar o simplificar el código muerto.

Prioridad: baja.

BA-04 — Conteo y nombres desactualizados en el README

Evidencia

- “34 archivos PHP” vs. 40 reales.
- Usuarios mencionados que no existen en el SQL.
- “CSRF nunca se conserva” vs. tres controladores que lo conservan.

Impacto

Documentación engañosa.

Recomendación

Actualizar el README o reemplazarlo por los manuales de `docs/`.

Prioridad: baja.

BA-05 — Artefacto PlantUML alternativo

Evidencia

`docs/casos-de-uso/casos_uso_general.puml` se generó como alternativa, pero los entregables finales son los SVG generados por `generar_diagramas.py`.

Impacto

Puede confundir sobre cuál es la fuente de verdad.

Recomendación

Eliminarlo o moverlo a una carpeta `borradores/` con una nota.

Prioridad: baja.

---

6. Revisión de controles de seguridad

CONTROL	ESTADO	OBSERVACIÓN
Autenticación	Correcta	`password_hash` / `password_verify`, rehash, cuentas activas.
Autorización	Correcta	`require_login` / `require_admin` en servidor.
Sesión	Buena con reservas	`strict_mode`, regeneración, `HttpOnly`, `SameSite`; falta `Secure`.
CSRF	Correcta	Token por sesión, `hash_equals`, rechazo de vacío.
XSS	Correcta	Escape con `e()` en vistas; CSP sin scripts inline.
Inyección SQL	Correcta	PDO preparado, sin emulación.
Validación de entrada	Buena	Reglas por entidad; algunas longitudes y formatos.
Manejo de errores	Correcto	Errores técnicos al log, mensaje genérico al usuario.
Auditoría	Parcial	Login, logout, admin CLI y facturas; faltan CRUD.
Rate limiting	Ausente	Sin límite de intentos.
HTTPS	Ausente	Sin TLS, HSTS ni cookie `Secure`.
Archivos internos	Protegidos	`public/` como raíz y `.htaccess` en carpetas internas.
Respaldos	No documentados	Sin automatización.
Dependencias	Mínimas	Sin Composer/CDN; fuentes locales.
Pruebas	Insuficientes	Solo lint.

7. Plan de acción recomendado

7.1 Inmediato (0–7 días)

1. Cambiar las contraseñas de `admin` y `mcajera`; desactivar cuentas demo.
2. Crear un usuario MySQL dedicado y retirar `root` sin contraseña.
3. Publicar detrás de HTTPS y añadir `Secure` + HSTS.
4. Habilitar `extension=gd` y probar la descarga PNG.
5. Programar un respaldo completo antes de cualquier cambio.
6. Corregir el README en los puntos de seguridad y conteo.

7.2 Corto plazo (1–4 semanas)

1. Implementar rate limiting y bloqueo temporal de login.
2. Centralizar la auditoría CRUD.
3. Sustituir el borrado físico de facturas por borrado lógico/archivado.
4. Guardar solo campos permitidos en `old_*` y eliminar el CSRF de la sesión.
5. Endurecer la política de contraseñas y forzar cambio inicial.
6. Usar un mensaje de login genérico.
7. Registrar el usuario que corrige una tasa.

7.3 Medio plazo (1–3 meses)

1. Añadir PHPUnit y pruebas de integración.
2. Configurar CI con lint + pruebas.
3. Automatizar respaldos y probar restauración.
4. Añadir MFA para ADMIN.
5. Revisar la CSP y mover estilos inline.
6. Definir política de retención fiscal con asesoría.
7. Añadir monitorización de errores y alertas.

7.4 Largo plazo (3–12 meses)

1. Migraciones formales de base de datos.
2. Observabilidad (logs estructurados, métricas, trazas).
3. Plan de continuidad y recuperación ante desastres.
4. Revisión de seguridad externa antes de crecer.
5. Evaluar un framework o una capa de seguridad mantenida si el sistema crece.

8. Conclusión

El sistema tiene una base técnica ordenada y varias decisiones acertadas: raíz web aislada, PDO preparado, CSRF, escape de salida, sesión estricta, autorización en servidor y facturación transaccional. Para un proyecto pequeño es un punto de partida sólido.

Sin embargo, **no está listo para producción tal como se entrega**: las credenciales demo, la conexión como `root` sin contraseña, la ausencia de HTTPS y de rate limiting, la auditoría parcial y el script SQL destructivo son riesgos que deben resolverse antes de exponerlo. La documentación también debe alinearse con el código.

Con las acciones inmediatas y de corto plazo de este informe, el sistema puede operar con un nivel de riesgo aceptable para un negocio pequeño, siempre con respaldos, HTTPS y una política de acceso disciplinada.

---

9. Anexos

9.1 Comandos usados en la revisión

```
# Conteo y lint de archivos PHP
$files = Get-ChildItem -Recurse -Filter *.php "C:\xampp\htdocs\revisionSistema"
$files.Count

# Extensiones
C:\xampp\php\php.exe -m

# Estado de MySQL
C:\xampp\mysql\bin\mysqladmin.exe -u root ping
```

9.2 Archivos clave revisados

ARCHIVO	ROL
`public/index.php`	Front controller y rutas
`config/helpers.php`	Sesión, CSRF, roles, formato y cabeceras
`config/database.php`	Conexión PDO
`config/empresa.php`	Datos fiscales de la empresa
`app/controladores/LoginController.php`	Autenticación
`app/controladores/FacturacionController.php`	POS, historial, PDF/PNG, anulación
`app/modelos/FacturaModel.php`	Emisión, consecutivo, stock y anulación
`app/controladores/ProductosController.php`	Inventario
`app/controladores/ClientesController.php`	Clientes
`app/controladores/MermasController.php`	Mermas
`app/controladores/TasasController.php`	Tasa BCV
`app/controladores/UsuariosController.php`	Usuarios y roles
`sql/de_todito_reyes.sql`	Esquema, vistas, triggers y datos demo
`tools/crear_admin.php`	Recuperación de ADMIN por consola

9.3 Documentos generados

- Manual de usuario
- Manual de instalación
- Índice de documentación
- Diagrama general de casos de uso
- Casos de uso del ADMIN
- Casos de uso del CAJERO
- Proceso de facturación

Revisión realizada sin ejecución del servidor MySQL. Las conclusiones funcionales se basan en lectura de código y esquema; las conclusiones de seguridad, en análisis estático y configuración del entorno.

ANEXO VISUAL · UML

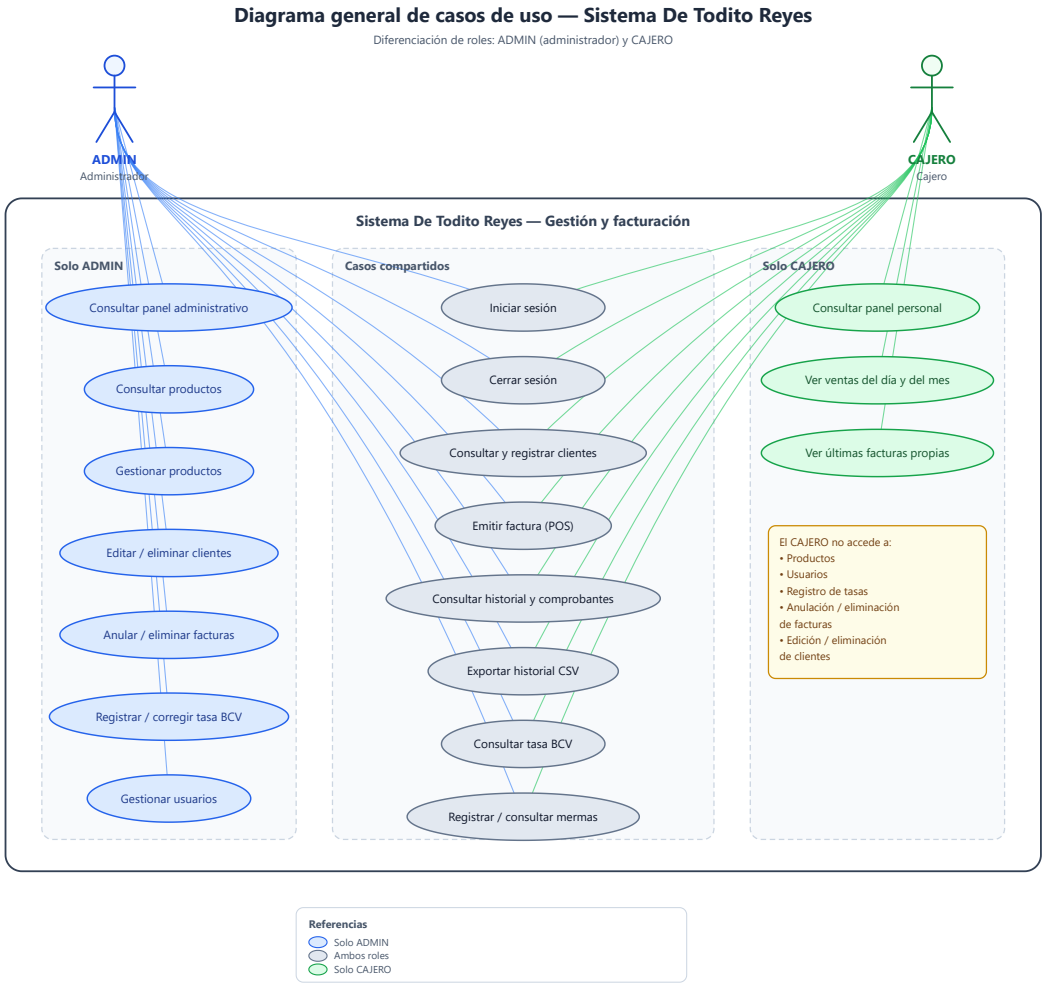
Diagramas de casos de uso

Los diagramas diferencian explícitamente los dos roles del sistema. El color azul identifica al **ADMIN** y el verde al **CAJERO**; las relaciones `<<include>>` se dibujan en violeta y las `<<extend>>` en naranja.

ADMIN CAJERO <<include>> <<extend>>

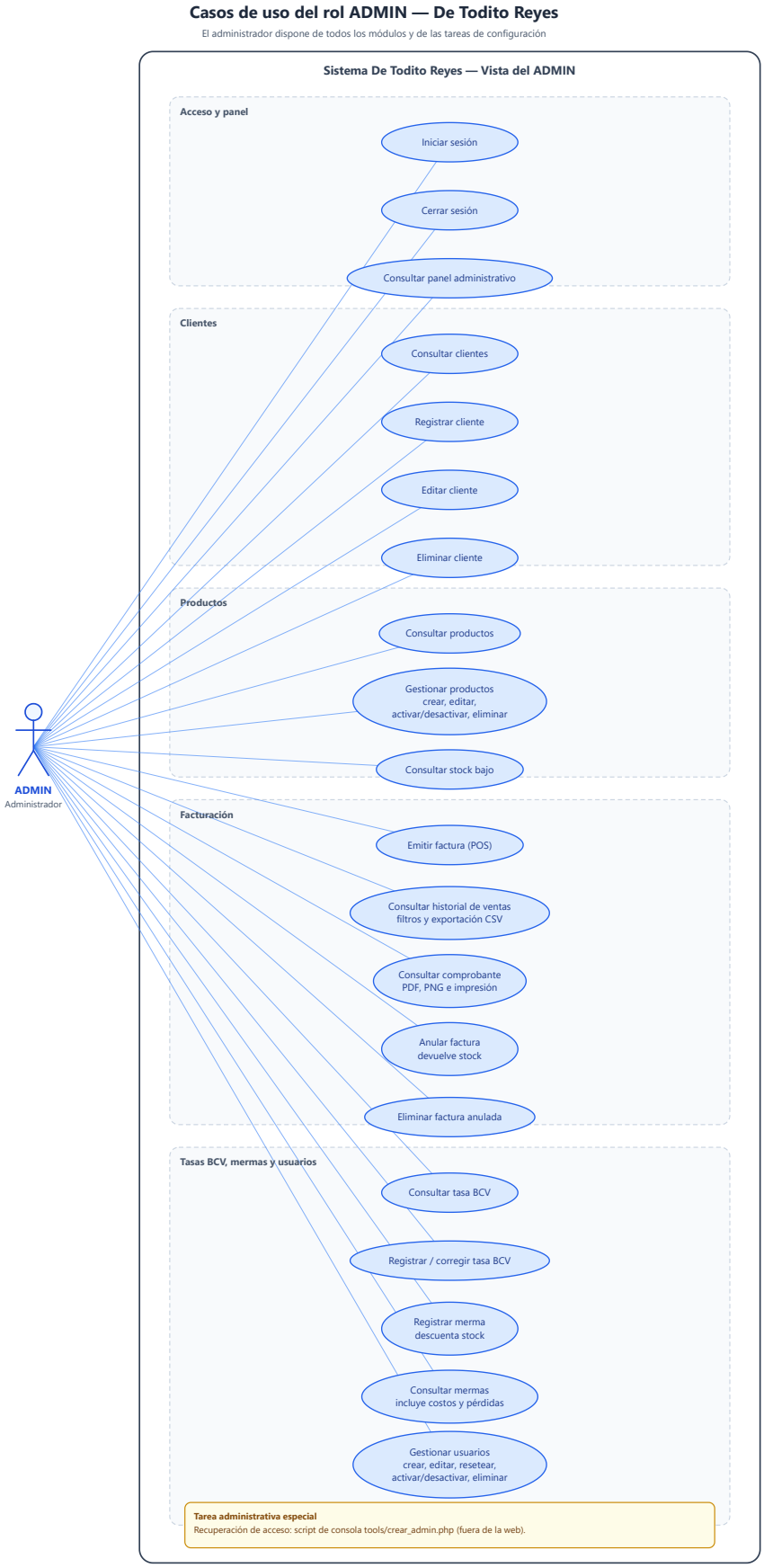
Diagrama general de casos de uso

Vista completa con la frontera del sistema y los dos actores.



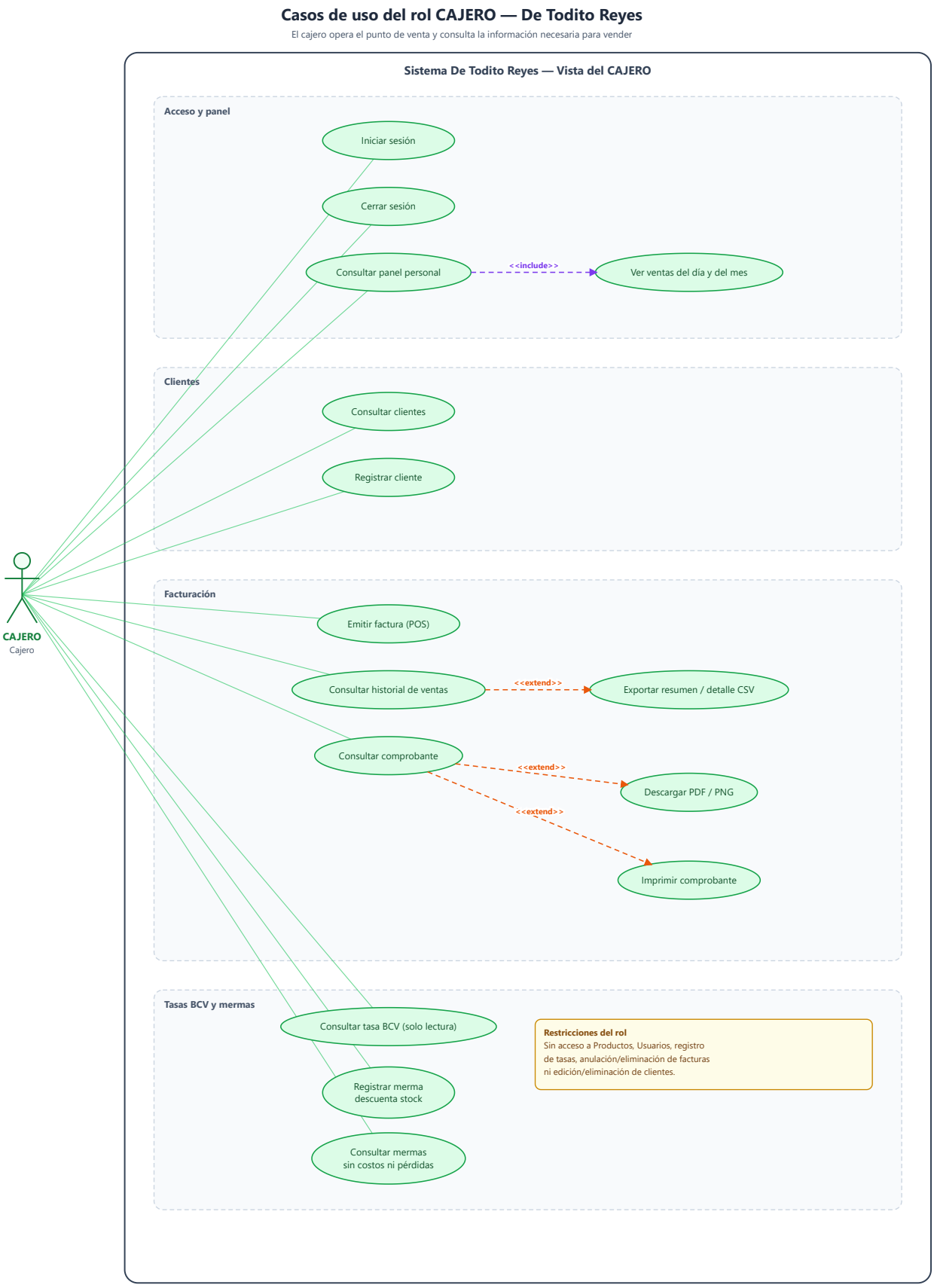
Casos de uso del ADMIN

Módulos exclusivos del administrador y sus relaciones.



Casos de uso del CAJERO

Operación de caja, consultas y límites de permisos.



Proceso de facturación

Flujo compartido del punto de venta, con include y extend.

